

Centro Integrado de Formación Profesional nº 1

UT 2 Seguridad Lógica

Curso: DAMSV_2A 2026-2027

Profesor: Miguel Ángel García Cejudo (miguelangel.garcia@educeuta.es)

Objetivos

- Reconocer las fases de un ataque y las medidas de seguridad lógicas que se pueden emplear para combatirlo.
- Conocer las diferentes políticas de seguridad que una empresa debe establecer: contraseñas, almacenamiento y copias de seguridad.
- Distinguir entre los distintos métodos y protocolos de autenticación y autorización actualmente existentes, con especial hincapié en las listas de control de acceso (ACL) y los sistemas de autenticación centralizada, respectivamente.
- Entender la diferencia entre los distintos tipos de copia de seguridad, cómo se realizan y cómo se restauran.

1. Introducción

Todo sistema informático debe ser asegurado mediante la correcta instalación, configuración y actualización del software de seguridad adecuado, para protegerlo ante posibles ataques que aprovechen vulnerabilidades o servicios mal configurados o protegidos.

1.1. Fases de un ataque

Todo ataque a un sistema informático suele llevarse a cabo en cinco fases muy definidas, según la certificación CEH (Certified Ethical Hacker):

1. Reconocimiento → 2. Escaneo → 3. Obtención de acceso → 4. Mantenimiento del acceso → 5. Borrado de huellas

A) **Reconocimiento** (reconnaissance)

Fase preparatoria en la que el atacante reúne toda la información posible de su objetivo, basándose en cualquier fuente, incluida la ingeniería social. Esta fase también puede incluir un escaneo no autorizado de la red (interno o externo).

1. Introducción

El potencial atacante diseña su estrategia de ataque, y para ello tarda el tiempo necesario para recabar la información crucial del objetivo. Para ello acude, si es necesario, a la basura de la víctima (dumpster diving), donde puede encontrar información de nombres de usuarios, contraseñas, números de tarjetas de crédito, recibos bancarios, números de teléfono, etc.

En general, las técnicas de reconocimiento pueden dividirse en activas y pasivas. Las técnicas activas implican la interacción con el sistema informático víctima, por ejemplo, el uso de herramientas para detectar puertos accesibles, routers, etc. Las técnicas pasivas no interactúan directamente con el sistema, sino que acopian información sobre este obtenida de fuentes públicas, ingeniería social, etc..

1. Introducción

B) **Escaneo** (scanning)

El escaneo es el método que un atacante lleva a cabo antes de atacar realmente el sistema víctima. Utiliza toda la información obtenida en la fase anterior para identificar vulnerabilidades específicas, por lo que esta fase puede considerarse una continuación lógica del reconocimiento activo.

En el escaneo habitualmente se utilizan herramientas automatizadas. Puede reunirse información crítica de la red utilizando comandos tan simples como un _traceroute_. Una vez identificados los equipos activos (_live systems_), se escanean los puertos abiertos, se identifican los servicios que están a la escucha, se identifica el sistema operativo subyacente, se elabora un mapa de equipos vulnerables alcanzables y, por último, se buscan las vulnerabilidades con software específico para este puede elegir entre utilizar los recursos de dicho sistema para lanzar un ataque posterior a otros equipos o permanecer explotando el sistema con un perfil bajo que le impida ser detectado. Sea cual sea la decisión esta misión (_vulnerability scanners_). Un administrador del sistema debe preocuparse de tapar todos los agujeros, pero un hacker solo necesita uno para entrar, por lo que siempre se encontrará en ventaja.

1. Introducción

C) **Obtención de acceso** (gaining access)

Esta fase es la más importante dentro del ataque, en términos de daño potencial, aunque no siempre es necesario ganar acceso al sistema para causar algún daño (por ejemplo, en las técnicas de denegación de servicio, agotando los recursos de la máquina).

Varios factores influyen en las posibilidades que tiene el atacante de ganar acceso al sistema objetivo: la arquitectura y configuración del sistema y, por supuesto, el nivel de destreza del atacante.

1. Introducción

D) **Mantenimiento del acceso** (maintaining access)

Una vez que el atacante ha conseguido acceder al sistema objetivo, este puede elegir entre utilizar los recursos de dicho sistema para lanzar un ataque posterior a otros equipos o permanecer explotando el sistema con un perfil bajo que le impida ser detectado. Sea cual sea la decisión, el atacante instala una puerta trasera (_backdoor_) que le permita volver a entrar sin ser detectado. Dicha puerta trasera puede inocularse en la forma de un troyano, un _rootkit_, etc.

Los atacantes pueden mantener el control sobre “sus” sistemas durante mucho tiempo, a lo largo del cual pueden dedicarse a robar datos, consumir ciclos de CPU, alterar información sensible, etc.

1. Introducción

E) **Borrado de huellas** (covering tracks)

Un atacante siempre quiere destruir las evidencias de su presencia y actuaciones en el sistema, principalmente por dos motivos: mantener el acceso y evitar consecuencias penales. Las huellas para borrar se encuentran en múltiples ficheros log del sistema: registro de inicios de sesión, posibles errores provocados por la fase de escaneo o la de penetración en el sistema, etc.

Es primordial para un atacante que el sistema tenga la misma apariencia que antes de que ganara acceso y estableciera la puerta trasera, por lo que no basta con eliminar líneas de ficheros log, sino que debe restaurar atributos de los ficheros alterados (tamaño, fecha de modificación, permisos).

Esta fase se inicia, realmente, junto con la anterior, pues es algo que el atacante debe hacer para garantizarse accesos futuros al sistema víctima. En cualquier caso, si el atacante decide no regresar, esta fase es claramente la última y definitiva.

1. Introducción

1.2. Medidas de seguridad

Como hemos dicho, el éxito en la penetración de un atacante depende de que el sistema tenga implantadas más o menos medidas de protección. Las principales medidas de seguridad que podemos adoptar en un sistema para evitar los ataques son las siguientes:

1. **Política de contraseñas**. Cada usuario del sistema debe disponer de una contraseña considerada segura, es decir, no debe ser fácil de averiguar por un atacante. La empresa puede imponer una política de contraseñas: normas que deben cumplir todas las contraseñas como longitud, complejidad, caducidad, etc.

2. **Listas de control de acceso**. Cada recurso del sistema, ya se trate de ficheros, directorios, aplicaciones o dispositivos, debe ser accesible únicamente a los usuarios que decida el administrador del sistema. Esto lo consigue mediante el establecimiento, en cada uno de los recursos anteriormente citados, de listas de control de acceso (ACL, por sus siglas en inglés), consistente en una lista de usuarios o grupos de usuarios a los que se les permite o deniega el acceso al recurso.

1. Introducción

1.2. Medidas de seguridad

3. **Criptografía**. Para garantizar la integridad, confidencialidad, autenticidad y no repudio de los datos almacenados o transmitidos.

4. **Política de almacenamiento**. La empresa debe gestionar el almacenamiento de datos basándose en el rendimiento, la disponibilidad y la accesibilidad, evitando dentro de lo posible los períodos fuera de servicio.

5. **Política de copia de seguridad**. Ante la eventual pérdida, robo o corrupción de los datos, es necesario disponer de copias de seguridad, las cuales deben ser creadas según parámetros establecidos de periodicidad, alcance, ubicación, cifrado, etc.

1. Introducción

1.2. Medidas de seguridad

6. **Protección ante el software malicioso** (malware). La empresa debe proteger sus equipos, datos y usuarios del efecto del software malévolo: desde la pérdida de tiempo y productividad que provoca el correo no deseado o spam, hasta el secuestro de datos por malware tipo CryptoLocker.

7. **Securización del software utilizado**. Una cosa debe quedarnos siempre clara: cualquier software puede (y suele) contener agujeros de seguridad, lo que nos obliga a una tarea permanente de actualización de este. Igualmente es necesario configurarlo de manera que pueda evitar o rechazar el máximo número de ataques, lo cual se consigue con técnicas de hardening.

8. **Seguridad perimetral**. La implantación de algún tipo de barrera que impida el acceso indiscriminado al sistema informático, normalmente en la forma de cortafuegos, proxies y VLAN.

9. **Alta disponibilidad.** La implantación de dos o más servidores redundantes que entran en funcionamiento según las necesidades de uso, o en caso de fallo del servidor primario. La virtualización de sistemas ha facilitado esta labor en los últimos años.

1. Introducción

1.2. Medidas de seguridad

La seguridad lógica es el tema principal del módulo. Todas estas medidas son tratadas en profundidad, la mayoría de ellas en unidades posteriores, con mención especial a la criptografía, por suponer la base de otras muchas medidas y merecer, por tanto, un capítulo aparte.

2. Política de contraseñas

La autenticación es el proceso por el cual un sistema informático confirma que alguien (o algo) es quien dice ser. Decimos algo porque, en un sistema informático, muchos recursos se ponen a disposición de procesos, servicios y aplicaciones, no solo de personas. Por ejemplo, un NAS puede requerir a un escáner algún tipo de identificación para permitirle almacenar el fichero JPG o PDF resultado de su escaneo.

Siempre se hablará de autenticación de personas en todos los casos, puede tratarse tanto de una persona como de un proceso informático.

La autenticación implica el uso de credenciales que solo debe conocer la persona identificada. Existen muchísimos tipos de sistemas de autenticación: contraseña (simple o doble), biométricos, tarjetas magnéticas de uso personal, etc., e incluso algunos que combinan dos o más criterios. Sea cual sea el método de autenticación, al finalizarlo nos encontraremos con solo dos posibles situaciones:

2. Política de contraseñas

- La persona es identificada como un usuario autorizado.
- La persona no es identificada como un usuario autorizado.

La segunda posibilidad, en realidad, incluye a su vez dos posibilidades: o es una persona no identificada como usuario autorizado o es una persona sí identificada como usuario, aunque se le ha retirado el permiso de ingreso o acceso (usuario bloqueado o deshabilitado).

Cuando una persona es identificada positivamente, es asociada con un usuario del sistema y se le permite el ingreso. A partir de ese momento, la decisión de si puede o no realizar alguna acción dentro del sistema depende de los permisos que tenga asignados su usuario, como veremos más adelante.

Nos vamos a centrar aquí en el método de credenciales por contraseña, por ser el más extendido (con diferencia) y el implementado en la totalidad de los sistemas operativos y en todo el software que incluye control de acceso.

2. Política de contraseñas

Al proceso de autenticarse para ingresar en un sistema se le conoce como login. Una vez autorizado el ingreso, se inicia una sesión de usuario, que acaba cuando el usuario cierra la sesión (proceso también conocido como logout).

La autenticación se basa en dos importantes principios de seguridad:

1. Las contraseñas son personales e intransferibles. Dicho de otro modo: un usuario nunca debe comunicarle su contraseña a otro usuario.

2. Cada persona que va a utilizar un sistema informático necesita un usuario y contraseña personales. Dicho de otro modo: dos personas no deben compartir usuario.

2. Política de contraseñas

Actividad propuesta 2.1

Elabora una lista de razones por las cuales, en el ordenador doméstico, cada miembro de la familia debería tener su propio usuario (y, por extensión, nunca usar contraseñas en blanco).

Aparte de estos principios, existen dos normas de oro dentro de la administración de sistemas:

- Nunca se debe dejar una contraseña por defecto.
- Nunca hay que abrir sesión como usuario administrador, excepto para tareas de administración.

2. Política de contraseñas

Efectivamente, uno de los motivos de ataque más frecuentes a puntos de acceso wifi domésticos es que el usuario no se ha preocupado (¡ni siquiera sabe!) de cambiar la contraseña de la interfaz de administración que viene de fábrica. Cualquier hacker no tiene más que consultar en internet las credenciales del usuario administrador para entrar cómodamente. De hecho, lo realmente recomendable es cambiar no solo la contraseña, sino también el nombre del usuario administrador, si el software lo permite, y nunca utilizar admin, administrador, root, etc.

En cuanto a la segunda norma de oro, toda persona administradora debe disponer de dos usuarios en el sistema: un usuario administrador, con permisos para realizar cualquier tarea, y un usuario limitado, como cualquier otra persona, para trabajar normalmente. ¿Y esto por qué?

Cuando un hacker (o software malicioso) accede a un equipo, podrá hacer poco daño si no tiene permisos suficientes. Por eso, cuando un hacker consigue entrar en un sistema suplantando a un usuario limitado, intenta averiguar las credenciales del usuario administrador (lo que se conoce como elevar privilegios). Si lo consigue, podrá hacer cualquier cosa en el sistema, incluso borrar el rastro de su actividad, dificultando cualquier auditoría de seguridad posterior.

2. Política de contraseñas

Los hackers, en un alto porcentaje de ocasiones, aprovechan para entrar en un sistema los agujeros de seguridad existentes en el software (exploits). Si ese software se está ejecutando con privilegios de administrador, el hacker ya tiene todo el trabajo hecho: puede abusar de nuestro sistema como le plazca. Si el software se está ejecutando con privilegios limitados, el hacker podrá aprovechar el agujero de seguridad para entrar, pero poco más podrá conseguir sin previamente elevar privilegios.

Esa es la razón por la que nunca debemos abrir sesión como usuario administrador para realizar tareas que no son de administración. De hecho, los sistemas operativos modernos permiten realizar tareas de administración desde la cuenta de un usuario limitado: simplemente solicitan credenciales de administrador para llevarlas a cabo.

2. Política de contraseñas

En Linux el usuario administrador siempre recibe el nombre de root. Una vez abierta sesión con un usuario limitado es posible convertirse en administrador ejecutando el comando "su" (SuperUser), el cual inicia una sesión como root.

```
usuario@equipo:~$ su
Password:
root@equipo:/home/usuario$
```

Algunas distribuciones, como Ubuntu, utilizan un comando llamado sudo (SuperUser DO) para ejecutar un comando concreto como root, sin necesidad de abrir temporalmente una sesión de root. De hecho, no es necesario conocer la contraseña de root, porque el comando sudo solicita la contraseña del usuario actual, lo que a simple vista parece un método muy poco riguroso. Sin embargo, se basa en que:

2. Política de contraseñas

- No todos los usuarios pueden ejecutar el comando sudo, sino solo los usuarios que pertenecen al grupo sudoers. De esta forma, el administrador del sistema incluye en ese grupo a los usuarios en los que confía para realizar tareas como root (quizá solo se incluya a sí mismo).

- Este sistema persigue que nunca se introduzca la contraseña de root, de modo que ningún malware pueda capturarla.

El resultado es un comportamiento similar al de Windows: cuando hay que realizar alguna tarea que requiera privilegios de administrador, se solicita una contraseña solicita realmente las credenciales de un administrador, mientras que Ubuntu solo la contraseña del usuario actual).

2. Política de contraseñas


```
usuario@equipo:~$ sudo apt-get update
[sudo] password for usuario:
```

Hay que destacar que Debian, la distribución de Linux en la que está basada Ubuntu, no dispone del comando sudo, excepto si se instala adrede.

Actividad propuesta 2.2

¿Qué inconvenientes se te ocurren que pueda tener el uso del comando sudo, en comparación con el sistema utilizado por Windows (solicitar las credenciales de un usuario administrador real)?

2. Política de contraseñas

Tanto los usuarios particulares como los empresariales deben definir una política de contraseñas para el acceso al sistema informático. Una política de contraseñas responde a las siguientes cuestiones:

- ¿Cómo de extensas han de ser las contraseñas? Hay que establecer un mínimo de caracteres.
- ¿Cómo de complejas han de ser las contraseñas? Hay que establecer la obligatoriedad o no de utilizar diferentes conjuntos de caracteres, como minúsculas, mayúsculas, números o signos de puntuación.
- ¿Cuánto tiempo ha de pasar para que una contraseña caduque? Hay que establecer el número de días pasados los cuales un usuario será obligado a cambiar de contraseña.
- ¿Cuántas contraseñas antiguas debe recordar el sistema? Hay que establecer el número de contraseñas de cada usuario que el sistema recuerda, para impedir que estos reutilicen contraseñas antiguas, con el menoscabo en la seguridad que eso implica.
- ¿Cuántas veces puede equivocarse un usuario al introducir su contraseña para ingresar al sistema? Hay que establecer el número de intentos tras los cuales el usuario quedará bloqueado.
- ¿Desde qué equipos está autorizado el usuario a acceder al sistema? Hay que definir los equipos (por MAC, IP, nombre...) desde los que cada usuario puede hacer login.

- ¿Se especifica una contraseña en BIOS/UEFI? ¿Solo para el acceso a la configuración BIOS o también para el arranque? Igualmente, en equipos con gestor de arranque, ¿debe este configurarse para solicitar una contraseña al arrancar el sistema operativo?

2. Política de contraseñas

Los sistemas operativos de escritorio orientados al público doméstico (Windows 10 o Ubuntu 19, por ejemplo) incluyen una política de contraseñas muy laxa. Prácticamente solo exigen un mínimo de caracteres e impiden utilizar el nombre del usuario como parte de la contraseña, pero poco más. Ni las contraseñas caducan, ni hay restricciones de ningún tipo.

No es el caso de los sistemas operativos empresariales (Windows Server, Red Hat, etc.), que sí dejan en manos del administrador el establecimiento de una política de contraseñas más seria.

También es cada vez más frecuente que, tanto los sistemas operativos móviles como las aplicaciones que requieren de login, dispongan de una política de contraseñas exigente (por ejemplo, bloqueando al usuario tras unos pocos intentos fallidos, indefinidamente o durante un tiempo concreto).

En resumen, cada sistema operativo y cada aplicación tiene su propia política de contraseñas, siendo esta configurable en algún aspecto en la mayoría de los casos.

2. Política de contraseñas

2.1 Verificación en dos pasos.
Los sistemas informáticos que necesitan un nivel superior de seguridad suelen implementar la autenticación con verificación en dos pasos o de doble factor (2FA, Two Factor Authentication).

Este método implica la introducción, además de la contraseña del usuario, de una prueba de identidad enviada al teléfono móvil del usuario.

En otras palabras, además de requerir del usuario algo que conoce (la contraseña), también se requiere algo que posee (el teléfono móvil).

Dicha prueba puede ser un código generado sobre la marcha, y que el usuario debe introducir en la pantalla de login, o un enlace sobre el que el usuario debe pulsar.

2. Política de contraseñas

La banca online es un típico ejemplo de aplicación que utiliza este tipo de autenticación para la autorización de pagos y transferencias. El software CMS (Content Management System), como WordPress, Drupal, etc., también suele disponer de plugins para incorporar la verificación en dos pasos, muchos de ellos basados en Google Authenticator, el sistema de verificación en dos pasos de Google. En general, cada vez más sistemas operativos, redes sociales, portales web, etc., dan como opción de autenticación la verificación de doble factor.

Actividad

Accede al portal de Google Authenticator y estudia su funcionamiento en la ayuda online. Compáralo con otras alternativas como son Microsoft Authenticator y Authy.

2. Política de contraseñas

U2F (Universal 2nd Factor) es un estándar abierto de autenticación que permite a los usuarios de internet el acceso seguro a múltiples servicios online con una única llave de seguridad, de manera instantánea y sin la instalación de drivers o software en el equipo cliente. Fue desarrollado por Google y Yubico, formando el germen de lo que ahora se conoce como FIDO Alliance (Fast Identity Online, fidoalliance.org). U2F ha sido adaptado por muchas grandes empresas como Facebook, Gmail, Amazon, etc.

La última generación del protocolo U2F ha recibido el nombre de FIDO2.

A grandes rasgos, U2F proporciona un marco con soporte para múltiples sistemas de autenticación. Las posibilidades son tremendas, al incorporar desde el uso de características biométricas (lectores de huellas o de iris, procesamiento de la voz, reconocimiento facial, etc.) a la utilización de dispositivos hardware de seguridad (dongles).

2. Política de contraseñas

La web de FIDO dispone de una sección de ayuda en la que se pueden encontrar diversos vídeos explicativos

Yubico fabrica llaves de seguridad USB certificadas por FIDO denominadas YubiKeys. Estos dongles pueden utilizarse para iniciar sesión en multitud de servicios, no solo online, sino incluso en sistemas operativos Linux (mediante un módulo PAM “Pluggable Authentication Modules“ de autenticación, los cuales serán tratados en el apartado 2.4.2) y Windows (mediante Windows Hello).





2. Política de contraseñas

2.3. Listas de control de accesos (ACL)

Una vez que un usuario ha sido autenticado, el sistema debe darle acceso solo a los recursos a los que ha sido autorizado por parte del administrador del sistema. Debemos, pues, distinguir claramente entre autenticación y autorización, siendo la primera un paso previo imprescindible para que se pueda producir la segunda. En un sistema informático, la autorización se consigue mediante dos características:

- Usuarios y grupos de usuarios.
- Listas de control de accesos (ACL, Access Control List).

El administrador define en el sistema uno o más grupos a los que pueden pertenecer los usuarios. Un grupo es simplemente un nombre que define un rol dentro del sistema, por ejemplo: "ventas", "contabilidad", "dirección", etc. Un usuario puede pertenecer a más de un grupo.

2. Política de contraseñas

2.3. Listas de control de accesos (ACL)

Normalmente el sistema operativo ya contiene un buen número de grupos predefinidos como "Todos los usuarios" (al que pertenecen automáticamente todos los usuarios del sistema), "Usuarios autenticados" (al que pertenecen automáticamente todos los usuarios que han iniciado sesión en el sistema), "Usuarios del dominio" (al que pertenecen automáticamente todos los usuarios sin bloquear del dominio Active Directory), "Administradores" (al que pertenece, al menos, el usuario administrador que instala el sistema operativo), etc.
El administrador asigna permisos a los recursos basándose en los usuarios y grupos existentes. Por ejemplo, el administrador puede asignar a la carpeta D:\Datos\Contabilidad permisos para que solo los grupos "contabilidad" y "dirección" puedan acceder a ella, mientras que el resto de los usuarios (por ejemplo, los pertenecientes al grupo "ventas") reciban un mensaje de error ("Acceso denegado", Access denied) si lo intentan.

2. Política de contraseñas

2.3. Listas de control de accesos (ACL)

Se considera una buena práctica no asignar nunca permisos a usuarios, sino hacerlo siempre a grupos. Incluso en los casos en los que un recurso solo debe ser accesible por un único usuario, es recomendable crear un grupo cuyo único miembro sea dicho usuario, y utilizar el nuevo grupo para asignarle permisos.

2. Política de contraseñas

2.3. Listas de control de accesos (ACL)

2.3.1. Tipos de permisos

Los tipos de permisos dependerán del tipo de recurso (dispositivo, socket, puerto, fichero, etc.). En el caso de los ficheros y carpetas, también depende del sistema operativo y del sistema de ficheros que se utilice. Uno de los sistemas operativos con mejor sistema de permisos es Windows (y su sistema de ficheros NTFS) y que permite controlar los siguientes, representando el primer nivel los permisos básicos y el segundo nivel los permisos avanzados:

2. Política de contraseñas

2.3.1. Tipos de permisos

Lectura:
- Entrar en carpeta / ejecutar fichero.
- Listar carpeta / leer fichero.
- Leer atributos.
- Leer permisos.

Escritura:
- Crear ficheros en carpeta / escribir datos.
- Crear carpetas / anexar datos.
- Escribir atributos.
- Eliminar subcarpetas y ficheros.
- Eliminar carpeta / fichero.

Administración:
- Tomar posesión.
- Cambiar permisos.
- Control total:
- Todo lo anterior.

2. Política de contraseñas

2.3.2. ACL

Todos los permisos anteriores se pueden conceder o denegar para uno o más usuarios o grupos, conformando lo que denominamos **Lista de Control de Acceso o ACL** (del inglés Access Control List). Una ACL es una lista de grupos o usuarios, con los permisos que se le conceden o deniegan a cada uno de ellos.

Como ya se ha comentado, los permisos que se pueden conceder o denegar dependen del sistema operativo y del sistema de ficheros que se utilice: ten en cuenta que la ACL es información que se almacena junto con la carpeta o fichero en cuestión, pues se trata de metadatos del mismo nivel que el propio nombre del fichero, sus fechas de creación y última actualización, su tamaño, etc.

2. Política de contraseñas

2.3.2. ACL

Los sistemas Linux, por ejemplo, que utilizan el sistema de ficheros ext4, solo disponen de los permisos de lectura, escritura y ejecución (rwx), asignables al dueño del fichero o directorio, al grupo de usuarios asignado al fichero o directorio, y al resto de usuarios (user, group, others).

-rwxrwxrwx

- Especial: Tipo de archivo.

rwx Permisos de usuario Permisos de lectura, escritura y ejecución para el propietario.

rwx Permisos de grupoPermisos de lectura, escritura y ejecución para el grupo.
rwx Permisos de otros. Permisos de lectura, escritura y ejecución para el resto de usuarios.

2. Política de contraseñas

2.3.2. ACL

Esto equivaldría a una ACL donde solo aparece el usuario dueño del fichero, su grupo principal y un grupo llamado "Resto de usuarios". Por lo tanto, para conseguir la granularidad que permite Windows, un administrador Linux tiene que recurrir a la creación de una gran cantidad de grupos, asignando a cada usuario (o proceso) varios grupos, según necesidades.

El mantenimiento de estos grupos se convierte en algo complejo, pues cada vez que se ve la necesidad de crear un nuevo grupo hay que incluir en él a todos los usuarios ya existentes que pueda interesar.

Afortunadamente Linux también permite permisos avanzados y ACL al estilo Windows. Para ello es necesario montar el sistema de ficheros con las opciones acl y user_xattr, y luego utilizar los comandos getfacl y setfacl para leer y modificar, respectivamente, las ACL de un directorio o fichero.

2. Política de contraseñas

2.3.2. ACL

Algunas distribuciones de Linux han desarrollado sistemas más avanzados de permisos, como es el caso de Red Hat con SELinux o de SUSE con AppArmor. La complejidad de dichos sistemas, destinados exclusivamente al mundo empresarial, hace que su explicación escape a los objetivos del presente libro.
A) Predominio de la denegación

La denegación predomina sobre la concesión. Esto es muy importante, y para entenderlo pondremos un ejemplo. Imagina un fichero con la siguiente ACL:

Grupo "dirección": permitir lectura.
Grupo "contabilidad": denegar lectura.
Si un usuario perteneciera a ambos grupos, no podría leer el fichero, pues la denegación tiene prioridad. Esto recibe el término inglés de deny-first.

2. Política de contraseñas

2.3.2. ACL

Imaginemos, sin embargo, que un usuario perteneciente al grupo "ventas" intenta acceder al mismo fichero. Al no tener ningún permiso especificado en la ACL para dicho grupo (ni concedido ni denegado), el acceso le queda prohibido también.

Prioridad de la denegación sobre la concesión.
Diagrama:

¿Se le deniega el acceso al usuario o a alguno de los grupos a los que pertenece?
Sí → Acceso denegado
No → siguiente comprobación, ¿Se le autoriza el acceso al usuario o a alguno de los grupos a los que pertenece?
Sí → Acceso permitido
No → Acceso denegado

2. Política de contraseñas

2.3.2. ACL

B) Herencia de permisos

Los permisos de las carpetas son heredados en las carpetas y los ficheros que contiene. Esta característica tiene dos ventajas:

El administrador no tiene que asignar permisos a subcarpetas ya existentes, excepto si van a diferir de los de la carpeta superior.
Los nuevos ficheros y subcarpetas contenidos en la carpeta actual recibirán automáticamente los mismos permisos, sin necesidad de que el administrador los asigne.

2. Política de contraseñas

2.3.2. ACL

Lógicamente, en cualquier carpeta o fichero podemos anular esta herencia y especificar los permisos que nos interesen. También es posible añadir permisos a los ya heredados.

El uso inteligente de la herencia de permisos es el que distingue a un buen administrador de otro mediocre.

2. Política de contraseñas

2.3.2. ACL

C) Permisos del administrador

El usuario administrador del equipo (o del dominio, si el equipo pertenece a un dominio Active Directory) no se ve afectado por las ACL. Si un directorio tuviera el permiso de acceso denegado para el grupo "Todos", aun así el administrador podría entrar a verlo. Cuando hablamos de usuario administrador también nos referimos a los usuarios pertenecientes al grupo "Administrador".

2. Política de contraseñas

2.3.2. ACL

D) Permisos en otro tipo de recursos

Hasta el momento nos hemos centrado en la asignación de permisos en ficheros y carpetas. Sin embargo, como dijimos en el apartado "Tipos de permisos", las ACL pueden controlar el acceso a otro tipo de recursos como dispositivos externos, sockets, impresoras, etc..

Es responsabilidad del administrador del sistema asignar debidamente los permisos a todos los recursos de este, no solo a las carpetas y ficheros.

Los sistemas Linux también definen permisos para otro tipo de recursos, pero lo hacen utilizando el directorio /dev, donde todos esos recursos están representados en forma de ficheros virtuales.

2. Política de contraseñas

2.4. Autenticación centralizada

Las redes de ordenadores (LAN) plantearon, desde sus inicios, el problema de la administración de usuarios. Inicialmente los administradores debían replicar la base de datos de usuarios en todos los equipos por dos motivos:

Un usuario podía querer o necesitar iniciar sesión en cualquiera de los equipos.
El almacenamiento compartido debía conocer todos los usuarios para poder asignar correctamente permisos de acceso a los datos.

Esto suponía grandes problemas de mantenimiento: altas y bajas de usuarios, cambios de contraseña, etc., así como otros de seguridad: un acceso indebido en uno de los equipos era difícil de detectar o rastrear desde los demás equipos, y una equivocación en la replicación de los usuarios y sus credenciales supone, por sí misma, una brecha de seguridad.

2. Política de contraseñas

2.4. Autenticación centralizada

Por este motivo, desde muy pronto se crearon métodos de gestión centralizada de los usuarios, de modo que

- El administrador solo mantiene una única base de datos de usuarios y grupos.
- Todos los equipos confrontan las credenciales del usuario que inicia sesión con esa base de datos centralizada.

2.4.1. Autenticación centralizada en Windows

Desde los primeros tiempos de Windows Server (cuando aún se denominaba Windows NT), la gestión centralizada de los usuarios de un mismo dominio quedaba a cargo de Active Directory. La base de datos de usuarios se almacena, junto con otra ingente cantidad de información, en unos servidores denominados controladores de dominio. Dicha base de datos se replica continuamente entre todos los controladores del dominio (si es que hay más de uno, que es lo recomendable) para que siempre esté disponible para los equipos de este, independientemente de que falle temporalmente uno de los controladores.

2. Política de contraseñas

2.4. Autenticación centralizada

2.4.1. Autenticación centralizada en Windows

La aplicación que permite la gestión de usuarios se llama "Usuarios y equipos de Active Directory". En ella es posible crear, editar y eliminar usuarios, equipos y grupos.

En Windows Server 2003 y anteriores solo era posible especificar políticas de contraseñas que afectaban a todos los usuarios del dominio por igual. En Windows Server 2008 ya era posible especificar políticas de contraseñas diferentes para distintos grupos de usuarios, aunque la forma de conseguirlo era muy tediosa. A partir de Windows Server 2012 es posible definir múltiples políticas de contraseñas y asignarlas a cualquier usuario o grupo al mismo estilo que se aplican directivas de grupo (GPO). Para ello debemos utilizar la aplicación "Centro Administrativo de Active Directory" (ejecutable dsac.exe).

2. Política de contraseñas

2.4. Autenticación centralizada

2.4.2. Autenticación centralizada en Linux

Linux es un sistema operativo capaz de autenticar a los usuarios de muchas maneras diferentes, pues utiliza un sistema modular llamado PAM (Pluggable Authentication Modules), que consiste en un conjunto de librerías para que el administrador elija el método que usarán las aplicaciones y el propio sistema operativo para autenticar a los usuarios.

Gracias a PAM, es posible cambiar de una autenticación por contraseñas a otra por reconocimiento facial (por ejemplo), sin necesidad de recompilar el kernel, sino simplemente configurando PAM para que utilice una librería de autenticación diferente. La diferencia entre unas librerías y otras puede residir no ya en el método de autenticación, sino simplemente en la diferente forma de cifrar las contraseñas o en el método de almacenamiento de estas.

2. Política de contraseñas

2.4. Autenticación centralizada

2.4.2. Autenticación centralizada en Linux

Todas las distribuciones de Linux incorporan el sistema PAM, y tienen habilitada por defecto la librería pam_unix.so de autenticación por contraseñas (la que utiliza los ficheros /etc/passwd y /etc/shadow como base de datos local de usuarios) dentro de su fichero de configuración /etc/pam.conf. La documentación relativa a PAM en www.linux-pam.org.

La forma, pues, de conseguir una gestión centralizada de usuarios en Linux consiste en configurar PAM para usar otra librería de autenticación que haga uso de una base de datos en red. De las librerías existentes destacamos LDAP (Lightweight Directory Access Protocol o Protocolo ligero de acceso a directorios), que mejoró las prestaciones de otra anterior llamada NIS (Network Information Service).

2. Política de contraseñas

2.4. Autenticación centralizada

2.4.2. Autenticación centralizada en Linux

LDAP no es ni más ni menos que una base de datos jerárquica, optimizada para realizar rápidamente búsquedas de información, a costa de penalizar la escritura de datos. Es, por tanto, perfecta para almacenar una base de datos de usuarios y grupos, cuyos datos se consultan con frecuencia pero rara vez sufren modificaciones. Tal es la potencia de LDAP que Active Directory es, en realidad, una versión mejorada y aumentada de LDAP. O, dicho de otro modo, Active Directory es un software LDAP al que se le ha añadido la capacidad de configuración centralizada de equipos mediante directivas de grupo (GPO, Group Policy Objects).

2. Política de contraseñas

2.4. Autenticación centralizada

2.4.3. Single sign-on

El concepto Single Sign-On (SSO) hace referencia a un método gracias al cual un usuario introduce sus credenciales una única vez, pero accede a diversas aplicaciones que, usualmente, requieren un inicio de sesión independiente.

Un ejemplo muy claro de SSO lo tenemos en las aplicaciones online de Google: una vez iniciada sesión en una de ellas, Gmail por ejemplo, es posible abrir otras aplicaciones que, "milagrosamente", no solicitan de nuevo el ingreso de la contraseña. Del mismo modo, al cerrar sesión en cualquiera de ellas, el resto quedan automáticamente inaccesibles.

2. Política de contraseñas

2.4. Autenticación centralizada

2.4.3. Single sign-on

Este método requiere de la existencia de un servidor de identidades central, accesible por todas las aplicaciones relacionadas y en el que todas ellas confían, el cual almacena las cuentas de los usuarios (habitualmente se trata de un servidor LDAP). Los datos que cada aplicación necesita de cada usuario son encapsulados en lo que se denomina un token de usuario (la mayoría de las aplicaciones web lo almacenan en forma de cookies dentro del navegador). Ese token es, precisamente, el que permite a una aplicación iniciar sesión por dicho usuario sin necesidad de que este vuelva a introducir sus credenciales.

2. Política de contraseñas

2.4. Autenticación centralizada

2.4.3. Single sign-on

Esquema del funcionamiento del sistema Single Sign-On (SSO):

1. Acceso a una aplicación web.
2. La aplicación web contacta con el servidor de identidades e intenta obtener el token de usuario.
3. Si el usuario aún no ha iniciado sesión, la aplicación redirige el navegador al servidor de identidades.
4. El servidor de identidades solicita las credenciales.
5. El usuario se autentica.
6. El servidor de identidades redirige el navegador a la aplicación web, con un token de usuario.
7. La aplicación web permite el acceso al usuario cuyos datos están contenidos en el token.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.3. Single sign-on

Las aplicaciones deben estar diseñadas específicamente para SSO, de modo que, cuando necesiten la autenticación del usuario, deleguen esa tarea al servidor de identidades SSO.

Relacionadas con SSO existen otras tecnologías como OpenID y Auth0, ambas diseñadas para facilitarle la vida al usuario de internet en su manejo de contraseñas. Es importante destacar que Auth0 es una API de programación mientras que OpenID es un protocolo (de hecho, OpenID hace uso de la especificación Auth 2.0).

2. Política de contraseñas

2.4. Autenticación centralizada

2.4.4. Protocolos de autenticación

Los procesos de autenticación en la red (ya sea LAN o WAN) son llevados a cabo mediante la utilización de alguno de los muchos protocolos existentes. Debemos tener en cuenta que, en el ámbito de una red, no solo los usuarios deben identificarse, también los equipos y los procesos pueden tener que autenticarse en busca de confianza mutua. Por ejemplo, un PC y un controlador de dominio deben autenticarse en entornos Active Directory; un navegador y un servidor web se identifican mutuamente en una sesión HTTPS.

En este ámbito debemos distinguir entre dos categorías de protocolos:

1. **Protocolos de autenticación**. Se trata de protocolos utilizados por otros protocolos superiores para llevar a cabo la fase de autenticación. Dicha fase incluye, por ejemplo, el envío de datos de sesión, contraseñas de un solo uso, hash MD5, certificados digitales, etc. Algunos de estos conceptos serán tratados en el próximo capítulo.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

2. **Protocolos AAA** (Authentication, Authorization and Accounting, es decir, Autenticación, Autorización y Contabilidad). En este caso son protocolos con un objetivo mucho más amplio: aparte de la autenticación permiten el intercambio de mensajes entre las dos partes para consultar la autorización de acceso a recursos. La parte de contabilidad hace referencia a la recopilación de información estadística sobre el consumo de los recursos de la red por los usuarios (tiempo de conexión, ancho de banda, etc.).

Los protocolos del segundo tipo (AAA) hacen uso internamente de protocolos del primer tipo para la fase de autenticación, motivo por el cual la confusión está asegurada para un inexperto en la materia.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

Muchos de los protocolos que, internamente, hacen uso de protocolos de autenticación, establecen una negociación para determinar cuál de estos utilizar, hasta acordar el considerado más seguro entre los conocidos por ambas partes.

Kerberos y la familia de protocolos EAP destacan en la primera categoría, mientras que entre los protocolos AAA el más extendido es RADIUS.

A) EAP

EAP (Extensible Authentication Protocol) no es propiamente un protocolo de autenticación, sino un sistema para transportar por la red métodos de autenticación. Actualmente hay alrededor de cien métodos diferentes, por lo que los protocolos de autenticación reales tienen nombres como EAP-MD5, EAP-AKA, EAP-MSCHAPv2, etc.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

PEAP (Protected EAP) es un protocolo que transmite cualquiera de los anteriores protocolos EAP por un túnel cifrado TLS previamente establecido entre los dos extremos.

B) Kerberos

El nombre de Kerberos proviene de la figura mitológica Cerberos, el perro de tres cabezas que vigilaba la puerta del reino de Hades, conocido también como Can Cerbero o Cancerbero. La elección de este nombre tiene sentido pues, en el modelo de autenticación Kerberos actúan tres servicios:

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

- El servicio de autenticación (AS, Authentication Server).
- El servicio de emisión de tickets (TGS, Ticket Granting Server).
- El servicio al que el usuario desea acceder, que puede ser una impresora, un dominio Active Directory o cualquier otro servicio cuya autenticación está basada en Kerberos.

Los dos primeros servicios pueden estar ubicados en máquinas diferentes, pero lo habitual es que estén en la misma, que en tal caso recibe el nombre de KDC (Key Distribution Center).

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

El proceso de autenticación de un usuario frente a un servicio al que desea acceder es el siguiente:

Esquema simplificado del funcionamiento del protocolo Kerberos

1. Soy Usuario. Necesito un TGT (Ticket Granting Ticket).
2. Aquí tienes tu TGT, si eres capaz de descifrarlo con tu contraseña.
3. Este es mi TGT. Necesito un ticket para el Servidor 1.
4. Aquí tienes tu ticket de servicio.
5. Este es mi ticket de servicio; autentícame.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación
Veamos cada paso con algo más de detalle:

1. El usuario (mejor dicho, su equipo) genera una clave secreta aplicando un algoritmo de cifrado a su propia contraseña. Envía al servidor AS una petición de TGT que incluye su nombre de usuario pero no la contraseña ni la clave secreta.

2. El servidor AS busca al usuario en su B. D. de credenciales y, usando el mismo algoritmo aplicado a la contraseña del usuario almacenada en la B. D., genera también la clave secreta. Haciendo uso de dicha clave secreta, encripta un ticket TGT, que no es más que un conjunto de datos que identifican al usuario, su equipo, la IP utilizada, la hora y otros detalles. El usuario recibe el ticket y, con su clave secreta (se supone que es idéntica a la usada por el servidor AS), descifra el TGT.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

3. El usuario se comunica ahora con el servidor TGS, solicitando un ticket de servicio para acceder al Servidor 1.

4. El servicio ofrecido por Servidor 1 es conocido por el TGS, por lo que genera el correspondiente ticket de servicio (cifrado, por supuesto), que devuelve al usuario.

5. El usuario, por fin, puede comunicarse con su objetivo primario: el Servidor 1. Para ello le envía el ticket conseguido en el paso anterior. Servidor 1 comprueba que se trata de un ticket válido, y concede el permiso de acceso al Usuario.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

Kerberos es, por tanto, una implementación particular de Single sign-on, pues una vez que el usuario se ha identificado en el AS, va recibiendo tickets hasta que cierra la sesión, lo que le permite autenticarse en más de un servicio sin volver a identificarse.

Para el correcto funcionamiento del protocolo Kerberos es imprescindible una perfecta sincronización de los relojes de todos los intervinientes en el proceso, o de lo contrario los tickets pueden entregarse con un periodo de validez que, para alguno de los intervinientes del proceso, se ha entendido como ya caducado. Por ello en redes donde se utiliza Kerberos es condición indispensable la sincronización de los relojes con el protocolo NTP (Network Time Protocol). Active Directory es uno de los sistemas que utiliza masivamente Kerberos para sus procesos de autenticación y, efectivamente, todos los equipos unidos al dominio sincronizan sus relojes con el del controlador del dominio al arrancar.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

C) RADIUS

El protocolo RADIUS (Remote Authentication Dial-In User Service) fue creado en 1991. De forma parecida a Kerberos, implica la intervención en el proceso de autenticación de un servidor RADIUS, el cual almacena los usuarios en una base de datos LDAP (o de cualquier otra clase). Dicho servidor contesta a consultas del tipo "¿Puede el usuario X conectarse? ¿Y iniciar sesión?".

Los mensajes RADIUS viajan encapsulados en tramas UDP (puerto 1812). Es habitual que los proveedores de internet hagan uso internamente de un servidor RADIUS para dar acceso a sus clientes. Por ejemplo, cuando enciendes el router doméstico que tienes en casa, este inicia una conexión (normalmente mediante protocolo punto a punto, PPP) con la central de tu proveedor de internet.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

C) RADIUS

Como parte del proceso de inicio de sesión, tu router comunica un nombre de usuario y una contraseña que están codificados en su configuración. El servidor comprueba, previa consulta al servidor RADIUS de la compañía, si tienes permiso para iniciar la conexión. Si estás al corriente del pago, la conexión se iniciará, pero si no es así, se rechazará y quedarás desconectado.

Gracias a la capacidad de RADIUS para controlar las sesiones de usuario (la tercera A de AAA), es posible acumular estadísticas de uso que permitan un control del ancho de banda del cliente o una facturación según consumo, por poner dos ejemplos.

2. Política de contraseñas

2.4. Autenticación centralizada
2.4.4. Protocolos de autenticación

D) Otros protocolos AAA

Anteriormente a RADIUS se utilizaba otro protocolo AAA con el original y estrambótico nombre de TACACS (Terminal Access Controller Access-Control System), es decir, sistema de control de acceso a los controladores de acceso a terminales. El fabricante Cisco realizó varias mejoras a este protocolo a lo largo del tiempo, hasta llegar en 1991 a la versión denominada TACACS+, parecido en funcionalidad a RADIUS pero operando sobre TCP en lugar de UDP.

2. Política de contraseñas

2.5. Política de almacenamiento

Los ordenadores trabajan con datos, y estos son almacenados en forma de ficheros. Que dichos ficheros sean almacenados y accedidos de forma segura es, por tanto, una de nuestras tareas más importantes como administradores de un sistema informático, y en ello influye la política de almacenamiento adoptada, que define en qué unidades de almacenamiento, dónde y cómo se almacenarán qué datos, en función de su cantidad e importancia.

Los puntos fundamentales sobre los que debe establecerse dicha política son los siguientes:

1. Ubicación: en entornos empresariales suele utilizarse almacenamiento centralizado, lo que facilita la gestión de las copias de seguridad. Esto implica elegir entre almacenamiento local, distribuido (remoto) o en la nube.

2. Política de contraseñas

2.5. Política de almacenamiento

2. Tipo: según el uso, rendimiento, capacidad o coste económico, habrá que elegir entre HDD, SSD o unidades de backup. La política de copias de seguridad (tratada en el apartado siguiente) influye de manera transcendental en el tipo y la ubicación de las unidades de almacenamiento.

3. Redundancia: ante la posibilidad de que una unidad falle y provoque la pérdida de datos, se puede implantar alguna solución RAID (Redundant Array of Independent Disks), escogiendo la más apropiada según funcionalidad, capacidad y coste.

4. Alta disponibilidad: si el almacenamiento es remoto, podemos necesitar que los datos sigan disponibles aunque falle una conexión, lo cual se consigue replicando los datos en dos o más ubicaciones diferentes, aunque el acceso se realice de forma transparente (como si fuera una única ubicación). La alta disponibilidad se consigue combinando redundancia con almacenamiento distribuido.

2. Política de contraseñas

2.5. Política de almacenamiento

Los tipos de unidades de almacenamiento, sus características fundamentales y las arquitecturas de almacenamiento de alta disponibilidad, son tratados en el módulo profesional Fundamentos de Hardware del primer curso. Asimismo, las matrices redundantes (RAID) son objeto de estudio del módulo profesional Implantación de Sistemas Operativos, también del primer curso. Por todo ello, el tratamiento que se hace en este apartado no entra, conscientemente, en demasiados detalles.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

Un RAID es un conjunto de dos o más unidades de almacenamiento que, en su conjunto, se comportan como una única unidad, proporcionando redundancia de los datos, es decir, no se producirá pérdida de datos en caso de avería de una de las unidades, pues los datos en ella contenidos están duplicados en una u otras unidades del conjunto o matriz. Los RAID no deben confundirse con otras arquitecturas que tienen como objetivo combinar la capacidad de almacenamiento de todas sus unidades, como es el caso de JBOD (en la cual se basan, por cierto, los volúmenes lógicos LVM de Linux).

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

Un RAID puede ser hardware o software. Para los primeros es necesario contar con una controladora de disco RAID; todo el proceso necesario para la replicación de datos entre las unidades de la matriz es realizado por la propia controladora, e incluso el sistema operativo ve el RAID como una única unidad de almacenamiento física. La gestión de los RAID por software, en cambio, recae en el sistema operativo, que es el que realiza la replicación de datos entre las unidades físicas y se encarga de mostrar a las aplicaciones y a los usuarios una única unidad lógica.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

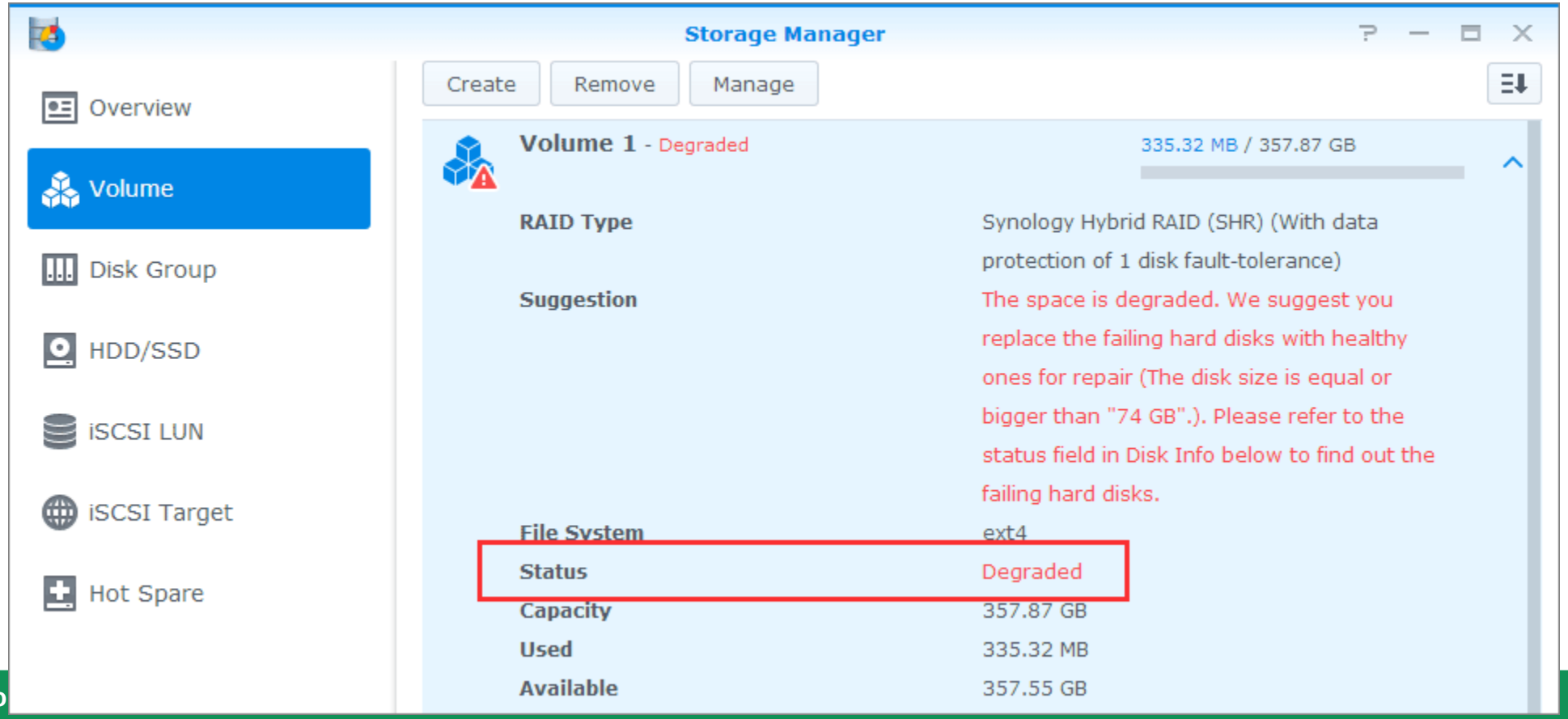
Al escribir los datos en un RAID, estos son replicados en las unidades de almacenamiento que lo conforman siguiendo algún algoritmo concreto de distribución de bloques. Si una unidad se avería, el RAID queda en modo degradado, pero continúa funcionando. El usuario no nota la avería ni se produce ninguna pérdida de datos. Dependiendo del número de discos del RAID y del algoritmo seleccionado, podrá faltar una segunda unidad sin que el RAID sufra pérdidas de datos, o incluso una tercera o cuarta. No obstante, la tarea de un administrador es sustituir cuanto antes el disco averiado para que el RAID se reconstruya automáticamente, es decir, rellene el nuevo disco con los datos que le corresponden, extrayéndolos del resto del RAID. El proceso de reconstrucción es siempre lento, más cuanta mayor capacidad tengan las unidades de almacenamiento, aunque el RAID sigue estando, mientras tanto, disponible para el sistema.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

Volumen RAID degradado por el fallo en un HDD, en un NAS Synology.



2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

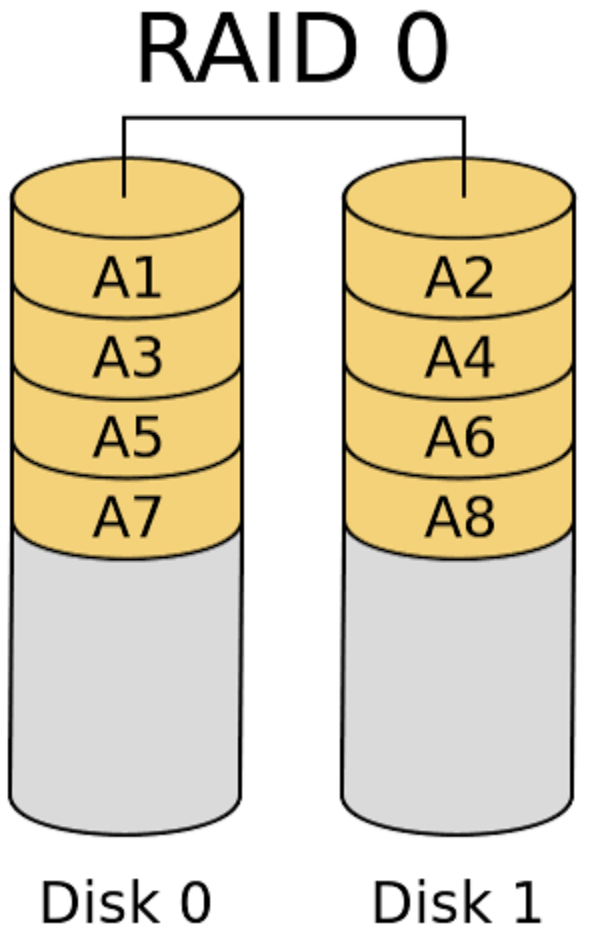
A) Niveles RAID

Existen diversas configuraciones de RAID, denominadas niveles RAID. Cada uno de ellos tiene sus ventajas e inconvenientes. Veremos los más comunes

2. Política de contraseñas

2.5. Política de almacenamiento
2.5.1. Redundancia
A) Niveles RAID
RAID 0

Explicación
No se trata de un nivel RAID, aunque así se le llame, pues no aporta redundancia. Consiste simplemente en distribuir los bloques en los discos del grupo, persiguiendo únicamente la combinación de capacidades de almacenamiento.
Número mínimo de discos necesarios
≥ 2
Ventajas e inconvenientes
Solo tiene una ventaja: la velocidad de lectura, pues la carga se reparte entre todas las unidades de la matriz, que leen los datos en paralelo.



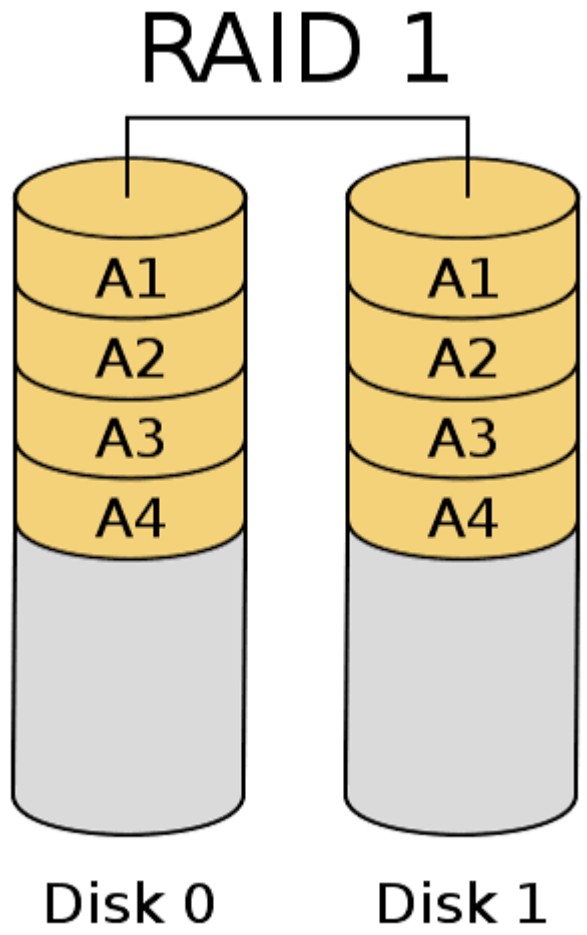
2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

A) Niveles RAID

RAID 1



Explicación

También llamado copia **espejo**. Duplica los datos en todas las unidades de la matriz.

Número mínimo de discos necesarios

≥ 2

Ventajas e inconvenientes

Su ventaja es la velocidad de escritura (no hay que calcular datos de paridad como en niveles superiores de RAID) y, especialmente, de lectura, pues se pueden obtener bloques en paralelo. Pueden averiarse todas las unidades de la matriz menos una, y seguirá funcionando.

En el lado negativo: por más unidades que se añadan nunca se aumenta la capacidad.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

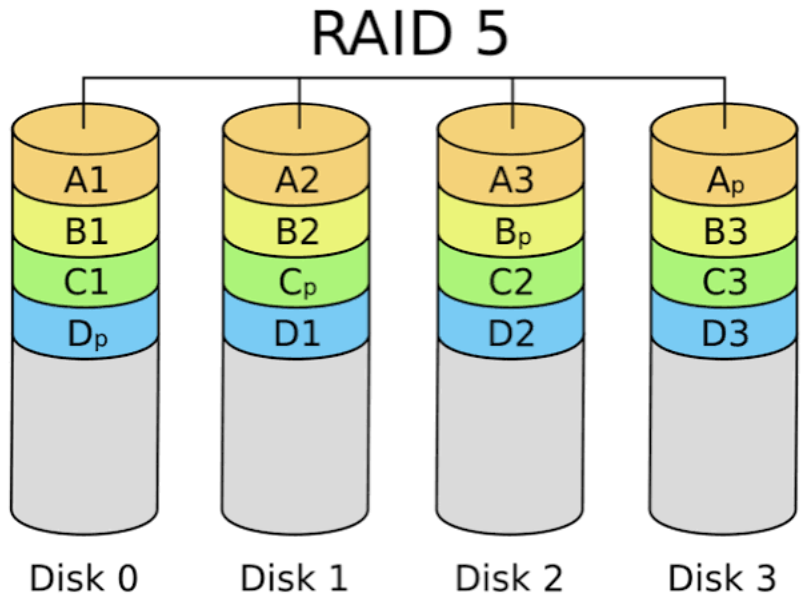
A) Niveles RAID

RAID 5

Explicación

Utiliza un algoritmo de cálculo de paridad para obtener un bloque especial que sirve para reconstruir los datos de cualquiera de los bloques empleados en el cálculo.

Por ejemplo, fijándonos en la imagen de la izquierda,
utilizando los bloques A1, A2 y Ap, podemos recalcular el bloque A3.



Número mínimo de discos necesarios

≥ 3

Ventajas e inconvenientes

Con RAID 5 obtenemos tanto redundancia como, en cierta medida, combinación de las capacidades de almacenamiento.

Sin embargo, solo admite un disco averiado; el fallo en un segundo disco implica la pérdida total de datos.

Las escrituras son lentas (por el cálculo de paridad), pero las lecturas son rápidas (se hacen en paralelo y no se usa la paridad), excepto en estado degradado, pues en tal caso también será necesario recurrir al cálculo de paridad.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

A) Niveles RAID

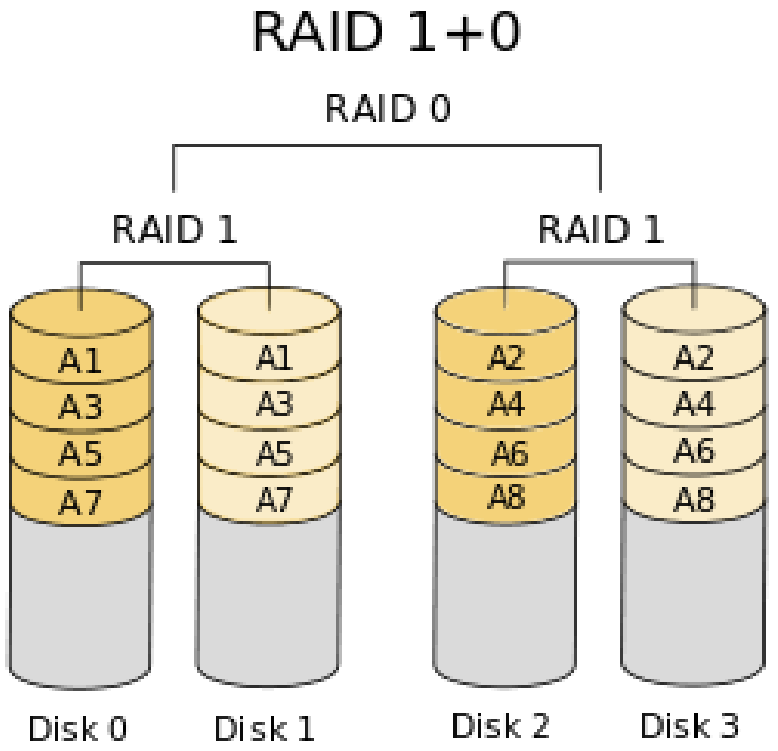
RAID 10 (1+0)

Explicación

Se consigue anidando dos o más RAID 1 hardware (de dos o más unidades cada uno) en un RAID 0 habitualmente software.

Número mínimo de discos necesarios

≥ 4



Ventajas e inconvenientes

Combina velocidad de acceso y redundancia, sin la sobrecarga que implica el cálculo de paridad. Soporta la avería de múltiples unidades, siempre y cuando no fallen dos del mismo grupo RAID 1.

2. Política de contraseñas

2.5. Política de almacenamiento

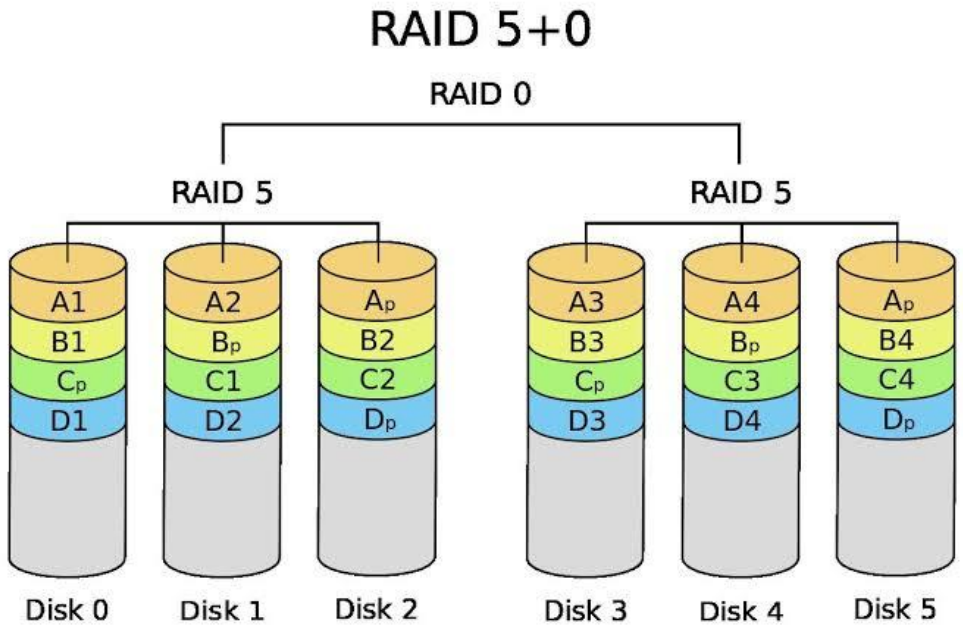
2.5.1. Redundancia

A) Niveles RAID

RAID 50 (5+0)

Explicación

Se consigue anidando dos o más RAID 5 hardware (de tres o más unidades cada uno) en un RAID 0 habitualmente software.



Número mínimo de discos necesarios

≥ 6

Ventajas e inconvenientes

Combina velocidad y redundancia. Soporta la avería de varias unidades, siempre que solo se produzca una como mucho dentro de cada grupo RAID 5.

2. Política de contraseñas

2.5. Política de almacenamiento
2.5.1. Redundancia
Actividad propuesta 2.5

En un equipo o máquina virtual Linux, con dos o más unidades de disco, configura un volumen RAID haciendo uso de la utilidad mdadm.

Repite la actividad con un equipo o máquina virtual Windows, haciendo uso de los espacios de almacenamiento (Panel de control > Espacios de almacenamiento), una tecnología propia de Microsoft similar al RAID pero, aseguran, más fácil de configurar.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

B) Hot Spare

El término inglés spare significa "de repuesto". Una unidad hot spare es, simplemente, una unidad de repuesto. La palabra hot hace referencia a que se trata de un disco instalado en el servidor y que pasa a ser utilizado de forma inmediata y automática en caso de necesidad. Es, por tanto, como la rueda de repuesto de un coche... si esta se cambiase mágicamente en caso de pinchazo sin intervención del conductor (de hecho, ¡sin que este se enterase!).

Muchas controladoras RAID, así como la inmensa mayoría de los NAS, admiten la configuración de una o más unidades hot spare, que sustituyen de forma automática a los discos averiados del RAID. El administrador, posteriormente, sustituye el disco averiado, sin necesidad siquiera de que termine la reparación del RAID, quedando la nueva unidad marcada como nuevo hot spare del sistema.

La existencia de los hot spare ha dado nombre a nuevos niveles RAID, como por ejemplo el nivel RAID 5E, que es, como puede imaginarse, un RAID 5 con hot spare.

2. Política de contraseñas

2.5. Política de almacenamiento
2.5.1. Redundancia
C) Criterios a la hora de elegir un nivel RAID

Un disco duro en perfecto estado también puede albergar un sistema de ficheros corrompido. Es decir, los datos no solo dependen de la salud de las unidades de almacenamiento, sino también de que no se produzcan problemas en el sistema de ficheros o en la tabla de particiones.
Un RAID protege (y hasta cierto punto, como hemos visto) de los problemas de averías físicas, pero no protege del resto de riesgos. Por lo tanto lo primero que debe quedar claro es que usar RAID es solo una medida de seguridad entre otras necesarias, como la presencia de un SAI y las copias de seguridad.
En cualquier caso, a la hora de elegir un nivel de RAID debemos evaluar la seguridad que aporta el nivel RAID elegido, su rendimiento y su coste económico.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.1. Redundancia

C) Criterios a la hora de elegir un nivel RAID

Por ejemplo, si disponemos de tres unidades de almacenamiento podemos elegir entre un RAID 1 y un RAID 5 (suponiendo que no queramos usar una de las tres como hot spare). Con un RAID 1 mejoramos en rendimiento y tolerancia a la avería de unidades, pero obtenemos menor capacidad. Con un RAID 5 mejoramos en capacidad pero empeoramos en rendimiento, aparte de arriesgarnos a una doble avería que nos dejaría sin datos.

Si existe la posibilidad de adquirir una cuarta unidad, podríamos optar por un RAID 10, que tiene un excelente rendimiento y nos puede servir para un servidor de bases de datos con una gran carga de trabajo, pero los riesgos ante averías múltiples en entornos tan exigentes nos obligarían a una política de copias de seguridad de mayor frecuencia... o a seguir añadiendo unidades al nivel RAID 1 anidado.

La decisión, por tanto, depende del administrador del sistema, que deberá valorar todos los factores.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

El uso de almacenamiento remoto, es decir, aquel ubicado en un servidor y accesible a través de la red (LAN o WAN), persigue los siguientes objetivos:

- Que todos los usuarios puedan acceder a los mismos datos sin necesidad de replicarlos en sus almacenamientos locales.
- Que se puedan implantar soluciones de redundancia y alta disponibilidad en lugares puntuales de una red, en vez de en todos los equipos de la red.

Existen multitud de protocolos cuya finalidad es el acceso remoto a datos. Algunos están orientados a ficheros (el cliente solicita una operación de lectura o escritura sobre un fichero concreto) y otros a bloques (el cliente solicita una operación de lectura o escritura sobre un bloque de la unidad remota de almacenamiento. Entre los primeros podemos señalar muchos: NFS, SMB, FTP, WebDAV, AFP, etc. Entre los segundos destaca iSCSI.)

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

A) iSCSI

El protocolo iSCSI (Internet SCSI) permite manipular un disco remoto o parte de él como si de una unidad física local se tratara, hasta el punto de que es posible **particionarlo y formatearlo** desde el sistema cliente. Todos los sistemas operativos, Windows entre ellos, pueden actuar como clientes iSCSI, permitiendo añadir unidades remotas mediante el uso de este protocolo. Es muy utilizado en virtualización para asignar discos físicos a máquinas virtuales.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

Lógicamente, la velocidad de la red empleada es muy importante, siendo imprescindible el uso de cableado óptico o Gigabit Ethernet (actualmente hasta 100 GbE). Este tipo de redes de alta velocidad, orientadas al almacenamiento iSCSI, recibe el nombre de redes SAN (Storage Area Network).

Los principales conceptos relacionados con esta tecnología son los siguientes:

- iSCSI LUN (Logical Unit Number) Es la unidad (o parte de ella) que el servidor iSCSI pone a disposición de los sistemas cliente.
- iSCSI Target o Destino iSCSIEs un identificador (llamado IQN o iSCSI Qualified Name, el cual debe ser único en la red) que el servidor iSCSI asigna al LUN, junto con su configuración de acceso, para que pueda ser utilizado por los sistemas cliente. Dentro de las opciones de configuración se encuentra la posibilidad de habilitar el protocolo de autenticación CHAP.

2. Política de contraseñas

2.5. Política de almacenamiento
2.5.2 Disponibilidad

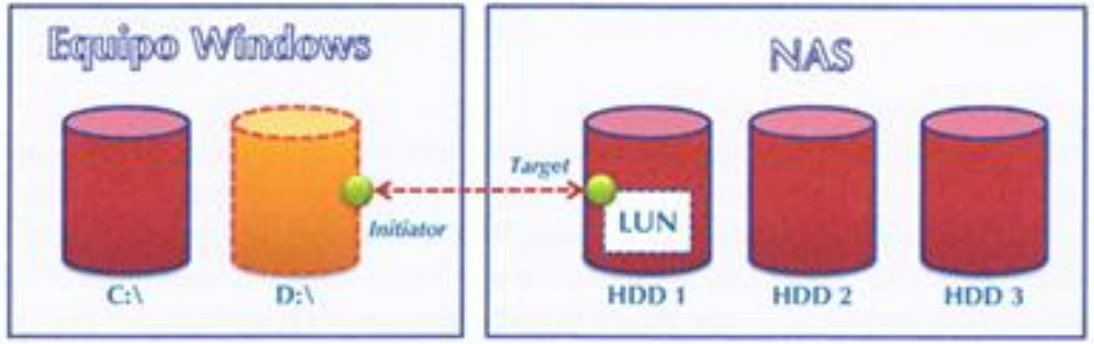
- iSCSI Initiator o Iniciador iSCSI Es el equivalente al bus SCSI, con la diferencia de que la controladora no envía los comandos SCSI por un bus físico, sino que lo hace a través de una red TCP/IP.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

Todos los NAS del mercado permiten crear iSCSI LUN, que pueden ocupar un disco completo o parte de él (o un RAID completo o parte de él). En la figura podemos ver un LUN que no ocupa un disco completo, sino parte de él. La creación de un iSCSI LUN en el NAS implica automáticamente la creación de al menos un iSCSI Target, o de lo contrario sería imposible acceder a él. Posteriormente, en otros equipos se puede crear un enlace al iSCSI Target, es decir, varios equipos pueden acceder simultáneamente al mismo LUN, y verlo todos ellos como un disco local, lo cual puede provocar corrupción en los datos a no ser que se utilice un sistema de ficheros específico para clústeres, como BTRFS.



2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

Para crear una unidad destino iSCSI en Windows es necesario seguir los siguientes pasos:

1. Debemos iniciar el servicio llamado Servicio del iniciador iSCSI de Microsoft.
2. Arrancamos la aplicación Iniciador iSCSI, y definimos un destino (target). Los destinos creados serán montados en el sistema tras cada arranque, como si de un disco local se tratara.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

Un iSCSI LUN puede estar alojado en un RAID, combinando así almacenamiento redundante y distribuido. Y también sería posible definir un RAID formado por unidades LUN (es decir, un RAID por software, que replique datos en unidades que, en realidad, son remotas). Esta última es una configuración un tanto estrambótica y de dudoso rendimiento, pero posible en todo caso. Aunque iSCSI no es una solución específica de alta disponibilidad, sí es utilizado como un mecanismo para recuperación rápida de sistemas con fallos. Por ejemplo, si un servidor de bases de datos almacena los datos en un LUN, será fácil y rápido reemplazarlo, tras una avería, por otro servidor que enganche con el mismo destino iSCSI, lo cual se asemeja bastante a la alta disponibilidad que trataremos posteriormente.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

Aquí nos hemos restringido al concepto básico de iSCSI, pero en realidad es un tema que puede ser bastante complejo de configurar y utilizar, especialmente si incluimos escenarios de las comunicaciones iSCSI, o la utilización de instantáneas (snapshots) del contenido del LUN.

Por otra parte, iSCSI no es el único sistema para acceder por bloques a unidades de almacenamiento a través de la red. En equipos Linux existe la posibilidad de descargar y compilar un módulo que habilita al kernel para manejar Network Block Devices (NBD, unidades de bloques en red), lo que constituye algo similar a iSCSI. Existen distintas versiones de este software, como la versión de Takiro Hirofuchi llamada xNBD

2. Política de contraseñas

2.5. Política de almacenamiento
2.5.2 Disponibilidad

B) Alta disponibilidad con NAS

Una red empresarial da la importancia justa a los equipos de los usuarios (si se produce una avería o una brecha de seguridad, son fáciles de reemplazar), pero centra toda su atención e inversión en los servidores que utilizan esos equipos. En cuanto al almacenamiento de datos se refiere, los servidores de archivos pueden ser cualquier servidor que comparta en red una unidad de almacenamiento o parte de ella, pero si se trata de hardware específicamente diseñado para esta misión (incluyendo su sistema operativo) adoptan, como ya sabemos, el nombre de NAS (Network Attached Storage o almacenamiento conectado a la red).

2. Política de contraseñas

2.5. Política de almacenamiento
2.5.2 Disponibilidad
B) Alta disponibilidad con NAS
Los servidores NAS de gama empresarial están preparados para funcionar como clúster, es decir, dos NAS interconectados que, de cara a la red, funcionan como un único NAS virtual, garantizando un servicio ininterrumpido (High Availability o HA). Uno de los NAS hace la función de servidor activo, pues es el que sirve los datos a la red, mientras que el otro hace de servidor pasivo, a la espera de un fallo en el primero para entrar en acción.

La conexión entre ambos NAS se denomina heartbeat connection (latido de corazón). Una red heartbeat es una red compartida por nodos de un clúster, y solo por ellos, independiente de la red local en la que se encuentran. En el caso que nos ocupa, al tratarse solo de dos nodos, no hablamos de red heartbeat, sino solo de conexión heartbeat.

2. Política de contraseñas

2.5. Política de almacenamiento
2.5.2 Disponibilidad
C) Almacenamiento en la nube

Existen multitud de soluciones de almacenamiento de datos en la nube, siendo este un concepto (el de “nube”) que pretende explicar de forma gráfica que los datos están en internet, pero no se sabe exactamente dónde ni cómo se gestionan. Las empresas dedicadas a este tipo de servicio ofrecen una cantidad de almacenamiento en función del coste, y el método para acceder a los datos, pero no se sabe en qué servidor (ni de qué país) se están almacenando. Y esto es así, entre otras cosas, porque dichas soluciones de almacenamiento proporcionan alta disponibilidad: según criterios de necesidad, espacio de almacenamiento, densidad de tráfico en la red, etc., los datos se clonan entre distintos servidores y en cada momento se está accediendo a una copia distinta de ellos.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

C) Almacenamiento en la nube

Con la irrupción en Europa de la legislación sobre protección de datos personales, y especialmente en España con la Ley Orgánica de Protección de Datos de 1999 (LOPD; se verá el último capítulo), se impone la necesidad de que los servidores que albergan datos personales deben estar en territorio europeo. Desde entonces, la mayoría de las empresas que ofrecen este servicio disponen de servidores para poder cumplir con esta normativa.

En cualquier caso, la contratación de este tipo de almacenamiento, desde el punto de vista de una empresa, debe pasar por un análisis previo de riesgos. A fin de cuentas, estamos cediendo nuestros datos, lo más valioso de la compañía, a otra empresa. Por lo tanto, no se puede elegir cualquier solución, debe ser la que nos brinde confianza sin escatimar en costes, pues aquí lo barato puede salir muy caro si la empresa en la que confiamos nuestros datos sufre un ataque o quiebra por insolvencia

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

C) Almacenamiento en la nube

Por otro lado, disponer de un almacenamiento en la nube también implica tener nuestros datos distribuidos, lo que aumenta la superficie expuesta a ataques. Y se trata de una “superficie” que nosotros no controlamos, sino la empresa proveedora, motivo adicional por el que debe ser de nuestra total confianza. De hecho, los almacenamientos en la nube son un “caramelo” para los hackers, pues suelen contener datos de multitud de empresas, lo que los convierte en un objetivo muy apetecible para obtener información tanto para hackers como para agencias nacionales de seguridad (como la NSA americana).

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

C) Almacenamiento en la nube

Existen soluciones de almacenamiento en la nube orientadas al usuario doméstico (seguramente ya conoces y utilizas alguna) y otras orientadas al empresarial. Todas ellas ofrecen file versioning . Dentro de las primeras tenemos Dropbox, Microsoft One Drive, Google Drive y Apple iCloud. Incluyen herramientas de sincronización de directorios, para aquellos usuarios que prefieran utilizarlas de ese modo. Las soluciones profesionales, en cambio, suelen estar orientadas a objetos o a bloques, no a ficheros. De este modo se ofrece la posibilidad de usar el almacenamiento como unidades remotas, con capacidad de realización de instantáneas, copias de seguridad, instalación de aplicaciones, etc. Las más importantes son las siguientes:

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

C) Almacenamiento en la nube

- Amazon S3: https://aws.amazon.com/s3/.
- Microsoft Azure Storage: https://azure.microsoft.com/es-es/product-categories/storage/.
- Oracle Cloud: https://cloud.oracle.com/es_ES/home.
- IBM SoftLayer: https://www.ibm.com/industries/es/es/softlayer/.
- Google Drive for Work: https://gsuite.google.com/driveforwork/.

Mas adelantes volveremos a tratar estas plataformas, más como soluciones de alta disponibilidad y alta adaptabilidad que como mero almacenamiento distribuido.

2. Política de contraseñas

2.5. Política de almacenamiento

2.5.2 Disponibilidad

Actividad propuesta 2.6

Es imposible abarcar en este capítulo la enorme cantidad de servicios que ofrecen estos productos aparte del evidente de almacenamiento remoto. Entra en las webs anteriores y realiza un listado de las características que ofrecen entre unos y otros. ¿Se parecen a los productos domésticos como Dropbox, o realmente estamos hablando de cosas muy diferentes? ¿Eres capaz de encontrar más soluciones similares a las anteriores? ¿Cuáles de ellas te ofrecen más confianza?

2. Política de contraseñas

2.6 Política de copias de seguridad

A pesar de las medidas de redundancia que se puedan implantar (RAID), es imprescindible hacer copias de seguridad de los datos por varios motivos:

- Salvaguardar datos ante un desastre del hardware.
- Salvaguardar datos ante modificaciones o eliminaciones producidas por hackers o virus (como los de la familia CryptoLocker).
- Disponer de una instantánea de nuestros datos en un momento del pasado.
- Acometer una mejora o migración de la infraestructura informática, por ejemplo reemplazo o reubicación de servidores físicos, actualizaciones entre versiones del sistema operativo, etc.

2. Política de contraseñas

2.6 Política de copias de seguridad

Además, si almacenamos datos personales, el Reglamento General de Protección de Datos (RGPD) nos obliga a realizar copias de seguridad periódicas del fichero. Si dicha copia de seguridad se prevé que pueda abandonar las instalaciones de la empresa, debe ser cifrada (la mayoría de las aplicaciones de copia de seguridad permiten esta opción).

Una copia de seguridad (backup) es un archivo o conjunto de archivos, almacenados en una ubicación denominada de destino (destination), que contiene una copia de los directorios y ficheros elegidos previamente por el usuario, denominados contenidos de origen (source). La copia de seguridad puede estar comprimida (para ocupar menos espacio) y cifrada (para evitar su lectura por personas no autorizadas). La compresión y el cifrado de una copia de seguridad tienen una contrapartida: son ligeramente más lentas de realizar y de restaurar por el mayor esfuerzo de proceso que ha de llevar a cabo la CPU.

2. Política de contraseñas

2.6 Política de copias de seguridad

Las copias de seguridad permiten restaurar la totalidad de los ficheros y directorios que contiene o, por lo general, también solo una selección de estos. Dependiendo del software de backup que utilicemos, podremos elegir el origen o será el software quien lo haga por nosotros. Por ejemplo, la copia de seguridad del servidor de Windows Server no da la posibilidad de elegir qué se debe salvaguardar, sino que es el sistema operativo el que escoge qué ha de incluir en el respaldo (en teoría, ¿quién mejor que él para saber lo que es importante en caso de restauración del sistema?).

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.1 Tipos de copia de seguridad

Existen distintos tipos de copia de seguridad:

1. **Completa** (full) :Una copia de seguridad que contiene todos los directorios y ficheros del origen.
2. **Diferencial** (diferencial):

Se salvaguardan únicamente los ficheros nuevos o que han sufrido cambios desde la anterior copia de seguridad completa. Es necesario, por tanto, disponer de ambas copias, completa y diferencial, para restaurar ficheros.

3. **Incremental** (incremental):

Se salvaguardan únicamente los ficheros nuevos o que han sufrido cambios desde la anterior copia de seguridad incremental. Es decir, la primera vez que se realiza una copia incremental equivale a una copia completa, pero en las sucesivas solo se almacenan los cambios. En la restauración es necesario disponer de todas las copias, desde la completa hasta la última incremental, para disponer de todos los ficheros. La copia incremental permite extraer ficheros de la última copia incremental o de las anteriores, consiguiendo ver así distintas versiones del mismo fichero. Esto es lo que se conoce como file versioning. Si el software de backup solo es capaz de restaurar la última versión de un fichero, estaremos hablando de copias incrementales puras, pero si permite acceder a las diferentes versiones del archivo registradas a lo largo del tiempo, hablamos de file versioning.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.1 Tipos de copia de seguridad

Completa
Lunes: 10 GB
Martes: 12 GB
Miércoles: 13 GB
Jueves: 15 GB
Viernes: 16 GB

Diferencial
Lunes: 10 GB
Martes: 2 GB
Miércoles: 3 GB
Jueves: 5 GB
Viernes: 6 GB

Incremental
Lunes: 10 GB
Martes: 2 GB
Miércoles: 1 GB
Jueves: 2 GB
Viernes: 1 GB

Cada tipo tiene sus ventajas e inconvenientes, lo que las hace útiles para cometidos diferentes

	Ventajas	Inconvenientes	Usos
Completa	En una sola copia tenemos todos los ficheros.	Tarda mucho tiempo. Cada copia ocupa mucho espacio. En cada copia se repiten innecesariamente ficheros que no han sufrido cambios	Copias de seguridad externas.
Diferencial	En solo dos copias tenemos todos los ficheros.	Cada día que se hace la diferencial, crece el tamaño, pues se almacena todo desde la copia completa. Parte del tiempo de proceso se pierde en comparar la copia completa con los ficheros actuales para ver si han sufrido cambios.	Copia de seguridad interna.
Incremental	Optimiza el espacio al salvaguardar solo los cambios. Exceptuando la primera copia completa, es la que emplea el menor tiempo.	Si no se hace una copia completa periódicamente, es necesario hacer uso de todas las copias para la restauración.	Copia de seguridad interna. File versioning.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.1 Tipos de copia de seguridad

Existe un último tipo de copia de seguridad, denominado **instantánea** (snapshot), aunque en realidad no es propiamente una copia de seguridad, sino que puede ser utilizada para realizar una copia de seguridad. Veamos en qué consiste.

En algunos sistemas de ficheros avanzados es posible crear una copia espejo prácticamente instantánea (de ahí su nombre) de una parte de este o de la totalidad, permitiendo no interrumpir el acceso a los ficheros. Este comportamiento determina las dos principales características de las instantáneas:

- El usuario puede seguir leyendo y escribiendo ficheros.
- La copia espejo es consistente.

Lo que se copia en una instantánea, realmente, son bloques del disco, no ficheros, de ahí que no sea posible realizar este tipo de copia en todos los sistemas de ficheros. Una vez realizada la instantánea, el software de backup puede dedicarse tranquilamente a hacer una copia de seguridad de la instantánea en segundo plano y, al finalizar, eliminarla. Es en este sentido que la instantánea en sí no es una copia de seguridad como tal, aunque ayuda a realizarla de manera consistente.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.1 Tipos de copia de seguridad

El software de virtualización se basa en las instantáneas también para realizar las copias de seguridad de las VM, que de este modo no cesan su actividad.

Windows también es capaz de realizar instantáneas con sus puntos de restauración. Cuando Windows crea un punto de restauración, está realizando una instantánea de una buena cantidad de directorios neurálgicos del sistema operativo (nunca de datos de usuario), de forma que sea fácil revertir el sistema a cualquiera de estos puntos. Dichas instantáneas son realizadas por el servicio Volume Shadow Copy (el sistema de ficheros nativo de Windows, NTFS, permite este tipo de instantáneas).

Los puntos de restauración de Windows están deshabilitados por omisión, es responsabilidad del usuario administrador activarlos, configurarlos por unidades y realizarlos manualmente en los momentos que interesen.

No debemos confundir los puntos de restauración de Windows con su control de versiones, aunque ambos conceptos están relacionados, ya que Windows es capaz de restaurar versiones antiguas de un fichero haciendo uso tanto de los puntos de restauración como del Historial de archivos (la nueva aplicación de copias de seguridad de Windows 10, Para ver las versiones de un fichero almacenadas por Windows solo tenemos que entrar en sus Propiedades, y luego en la pestaña Versiones anteriores (Windows nos permite abrir o restaurar cada una de estas versiones).

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.1 Tipos de copia de seguridad

Tanto los puntos de restauración como el control de versiones pueden ser de gran utilidad para el usuario doméstico, aunque eso no le ahorra la necesidad de realizar copias de seguridad externas al equipo

Actividad propuesta 2.7

Ya hemos visto que el sistema de ficheros NTFS utilizado por Windows permite las instantáneas. Averigua qué sistemas de ficheros lo permiten en el planeta Linux.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.2. Elementos de la política de copias de seguridad

Tanto los usuarios particulares como las empresas deben seguir una política de copias de seguridad bien definida, la cual deberá incluir:

- Qué datos se desea salvaguardar (el origen).
- Con qué frecuencia se realizará la copia y en qué horario (temporización).
- Dónde se almacenará(n) esa(s) copia(s) de seguridad (el destino).
- Cómo se almacenarán, en cuanto a tipo de copia, compresión y cifrado de los datos.
- Quién custodiará las copias de seguridad, especialmente si son copias externas. Si no salen de la empresa, hay que buscar una ubicación segura, habitualmente una caja fuerte ignífuga; si van a sacarse de la empresa deben ir cifradas y recaer en una persona concreta (y designada especialmente para tal fin) la responsabilidad de su custodia, tratándose normalmente de un miembro de la dirección.

El tipo de copia elegida también influye en la temporización. Por ejemplo, si elegimos una copia diferencial, habrá que elegir qué días se realiza la copia completa y qué días la diferencial.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.2. Elementos de la política de copias de seguridad

En usuarios particulares lo normal es realizar copias completas con una frecuencia amplia. Sin embargo, en el mundo empresarial las copias se deben realizar con muchísima frecuencia, tanto como se pueda permitir. Lo normal es una copia diaria, pero en ciertos casos de datos muy sensibles se recurre a copias incrementales cada hora.

La política de copias de seguridad recibe también el nombre de estrategia BCDR (Business Continuity and Disaster Recovery), es decir, "estrategia de continuidad empresarial y recuperación ante desastres".

El software de backup suele permitir la creación de múltiples trabajos o tareas (Jobs o tasks), cada uno de ellos con sus propiedades: origen, destino, tipo, compresión, cifrado y, sobre todo, temporización. Normalmente las empresas emplean planes de copias de seguridad mixtos: algunos trabajos tienen destinos en almacenamiento local, mientras que otros los tienen en almacenamiento en la nube.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.2. Elementos de la política de copias de seguridad

Toda empresa debe contar con una política de copias de seguridad bien definida. En caso de contener datos personales, el Reglamento General de Protección de Datos obliga a llevar un inventario de dispositivos de almacenamiento de backup y un registro de todas las copias de seguridad realizadas, y especialmente de cuándo ha sido necesario restaurar alguna y por qué.

La política de seguridad será tanto más estricta (mayor frecuencia, cifrado fuerte, etc.) cuanto más valiosos sean los datos a salvaguardar. La elección de una política u otra depende, pues, de lo que ha venido a denominarse el nivel de pánico: dependiendo del pánico a perder los datos actuaremos de forma más "neurótica" o más "calmada".

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.3. Aplicaciones de copia de seguridad

En un equipo individual, las copias de seguridad se pueden realizar con distintas aplicaciones:

El propio sistema operativo suele incluir una aplicación para este menester. En Windows, por ejemplo, disponemos de Copias de seguridad y restauración, aunque desde Windows 10 se denomina Historial de archivos y forma parte de la Configuración del sistema.

Aplicación específica: existen multitud de ellas en Internet, algunas muy potentes y de pago, y otras más simples y gratuitas. Quizá el caso más extendido por ser gratuito e incluir gran cantidad de opciones es Cobian Backup (cobiansoft.com).

Muchos discos externos y pendrives incorporan el software de backup propietario de la marca.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.3. Aplicaciones de copia de seguridad

En un equipo individual, las copias de seguridad se pueden realizar con distintas aplicaciones:

El propio sistema operativo suele incluir una aplicación para este menester. En Windows, por ejemplo, disponemos de Copias de seguridad y restauración, aunque desde Windows 10 se denomina Historial de archivos y forma parte de la Configuración del sistema.

Aplicación específica: existen multitud de ellas en Internet, algunas muy potentes y de pago, y otras más simples y gratuitas. Quizá el caso más extendido por ser gratuito e incluir gran cantidad de opciones es Cobian Backup (cobiansoft.com).

Muchos discos externos y pendrives incorporan el software de backup propietario de la marca.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.3. Aplicaciones de copia de seguridad

Actividad propuesta 2.8

En un equipo Windows, activa el Historial de archivos y configúralo de forma que realice copias del directorio de Documentos del usuario en una unidad USB.

En los servidores empresariales las copias de seguridad son siempre realizadas con software especializado:

- El software de virtualización, como hemos comentado, ya incluye todas las opciones necesarias para la realización y restauración de copias de seguridad de las máquinas virtuales.
- Aplicaciones comerciales especializadas, siendo una de las más conocidas Acronis Backup (acronis.com).
- Los sistemas operativos de servidor, especialmente los de NAS, ya incluyen aplicaciones especializadas, que permiten realizar copias locales, externas, remotas e incluso en la nube, todas ellas del tipo file versioning. Windows Server incluye la aplicación Copias de seguridad de Windows Server para este cometido, pero sus funcionalidades excesivamente básicas llevan a muchos administradores a adquirir otra solución más potente de Microsoft llamada Data Protection Manager (DPM).

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.3. Aplicaciones de copia de seguridad

El software actual de copias de seguridad incrementales ha avanzado de tal forma que ya no se almacenan los ficheros nuevos y modificados, sino los sectores de disco nuevos y modificados. Esto es una gran ventaja a la hora de almacenar grandes ficheros que suelen ser alterados diariamente, como por ejemplo bases de datos o almacenes de correo electrónico. En una copia incremental estándar, estos ficheros serían siempre incluidos al completo en las sucesivas copias de seguridad , mientras que en las incrementales por sectores se almacenarían únicamente los sectores del disco relacionados con esos ficheros que realmente han sido modificados

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.4. Restauración de copias de seguridad

Las copias de seguridad son algo que debe hacerse con frecuencia, empleando tiempo y recursos para ello, a pesar de que en una situación ideal nunca se recurrirá a ellas. Pero eso es en un mundo ideal. En el mundo real, antes o después, hay que restaurar una copia de seguridad. Estos son los principales motivos por los que se recurre a restaurar una copia (o parte de ella):

- Algún sujeto (persona, aplicación, virus, etc.) ha eliminado o corrompido ficheros.
- El sistema operativo, o alguna aplicación, ha dejado de funcionar correctamente tras una actualización.
- El disco duro que almacena los ficheros se ha averiado y hay que sustituirlo por otro.
- Es necesario acceder a un fichero ya eliminado o a una versión anterior.
- Es necesario conocer los ficheros existentes en un momento concreto del pasado.
- Es necesario comparar un fichero actual con una versión anterior.

Es importante tener presente que, al restaurar un fichero, la versión antigua sobrescribe a la actual. Esto es cierto tanto para restauraciones completas como de ficheros individuales. Por lo tanto, si nuestra intención es comparar dos versiones del mismo fichero, deberemos usar un software especializado, o renombrar el fichero actual para que no sea sobrescrito por la versión antigua.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.4. Restauración de copias de seguridad

Actividad propuesta 2.9

Cuando se avería un disco duro y no disponemos de copia de seguridad o la misma no incluye datos malogrados, es necesario intentar recuperar el contenido del disco. Hay empresas que consiguen recuperar un alto porcentaje del contenido de cualquier disco averiado, incluso de ficheros previamente eliminados.
Busca en internet empresas que proporcionen este servicio, y plantéate las siguientes preguntas:
¿Cuánto pagarías por recuperar información vital que solo está almacenada en un disco averiado?
¿Cómo hay que borrar definitivamente el contenido de un disco que queremos desechar, conscientes de que existen métodos para recuperar su contenido?

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.5. Caso práctico: ejemplo de política de copia de seguridad en una pyme

Imaginemos una pequeña o mediana empresa (pyme) con el siguiente sistema informático:

Caso práctico: ejemplo de política de copia de seguridad en una pyme
1. Servidor Dell

Un servidor Dell, procesador Intel Xeon E5 de 10 núcleos, 4 bahías, 32 GB de RAM, tres HDD de 500 GB.

- Tiene instalado Proxmox, gracias al cual la empresa dispone de varias máquinas virtuales (VM) que ofrecen los servicios de Active Directory, servidor web y servidor de base de datos. Aún le sobra memoria RAM para ampliar estas VM o crear otras, llegado el caso.
- Los tres HDD del servidor Dell están montados en RAID 5.
- La cuarta bahía queda libre para una posible ampliación futura.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.5. Caso práctico: ejemplo de política de copia de seguridad en una pyme

2. Un NAS Synology de 6 bahías, con 2 GB de RAM, 3 HDD de 4 TB, 2 HDD de 6 TB y 1 SSD externo de 512 MB.

- Las bahías 1 y 2 tienen HDD de 4 TB montados en RAID 1. Este volumen es utilizado para almacenamiento de los datos de la empresa.
- La bahía 3 tiene el otro HDD de 4 TB montado como hot spare de los dos anteriores.
- Las bahías 4 y 5 tienen los HDD de 6 TB montados en RAID 1. Este volumen está destinado a copias de seguridad de versiones por sector. Dicha copia de seguridad almacena un máximo de 6 meses de versiones.
- La bahía 6 queda libre para uso futuro o en caso de necesidad de ampliación.
- El SSD se conecta por USB 3.0 para hacer la función de caché.

3. Dos HDD externos eSATA de 6 TB

Estas unidades son utilizadas para copias de seguridad externas alternas.

4. Una cuenta Amazon S3 de 50 TB

Este almacenamiento en la nube es utilizado como sistema adicional de copia de seguridad para salvaguardar los datos ante posibles desastres (la empresa está ubicada en una zona de terremotos frecuentes).

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.5. Caso práctico: ejemplo de política de copia de seguridad en una pyme

5. Una conexión a Internet por fibra óptica de 600 Mbps simétricos.

6. 30 equipos PC para los usuarios, con procesador i5, 8 GB de RAM y HDD de 512 GB. Sistema operativo Windows 10. Todos ellos unidos al dominio Active Directory.

Como podemos ver, todos los HDD del CPD están protegidos ante averías por RAID 1. En caso de producirse una, el administrador comprará un HDD nuevo para sustituir al defectuoso (de hecho, en muchas empresas es habitual disponer de discos de repuesto). Los datos más importantes de la empresa, alojados en el NAS Synology, disponen como medida de seguridad adicional de un tercer HDD como hot spare del RAID de datos.

Con este CPD, el administrador de la empresa diseña la siguiente política de copias de seguridad:

1.Cada madrugada a las 1:00 se realiza un backup de las VM de Proxmox en el NAS Synology, haciendo uso de copias de seguridad por instantánea. De este modo, las VM nunca se detienen. En caso de problema en alguna de las VM, es posible restaurarla a como se encontraba la noche anterior.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.5. Caso práctico: ejemplo de política de copia de seguridad en una pyme

2. Un NAS Synology

Un NAS Synology de 6 bahías, con 2 GB de RAM, 3 HDD de 4 TB, 2 HDD de 6 TB y 1 SSD externo de 512 MB.

Las bahías 1 y 2 tienen HDD de 4 TB montados en RAID 1. Este volumen es utilizado para almacenamiento de los datos de la empresa.
La bahía 3 tiene el otro HDD de 4 TB montado como hot spare de los dos anteriores.
Las bahías 4 y 5 tienen los HDD de 6 TB montados en RAID 1. Este volumen está destinado a copias de seguridad de versiones por sector. Dicha copia de seguridad almacena un máximo de 6 meses de versiones.
La bahía 6 queda libre para uso futuro o en caso de necesidad de ampliación.
El SSD se conecta por USB 3.0 para hacer la función de caché.

3. Dos HDD externos eSATA de 6 TB

Estas unidades son utilizadas para copias de seguridad externas alternas.

4. Una cuenta Amazon S3 de 50 TB

Este almacenamiento en la nube es utilizado como sistema adicional de copia de seguridad para salvaguardar los datos ante posibles desastres (la empresa está ubicada en una zona de terremotos frecuentes).

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.5. Caso práctico: ejemplo de política de copia de seguridad en una pyme

2. Cada madrugada a las 3:00 el NAS Synology realiza copias de seguridad de las carpetas de datos en su volumen destinado a copias de seguridad. Al ser una copia de seguridad de versiones por sectores nos garantiza el mínimo tiempo y espacio de las copias, al mismo tiempo que podemos recuperar cualquier fichero a un estado anterior dentro de los seis últimos meses.

3.Cada semana, el administrador trae de una caja fuerte (externa a la sede de la empresa) uno de los HDD eSATA, lo conecta al NAS, y realiza una copia de seguridad completa, comprimida y cifrada de los datos. Cada semana hace uso de uno de los discos, de forma alternativa. De esta forma, ante un desastre en la sede de la empresa, es posible recuperar los datos más importantes (que tendrán un desfase máximo de 7 días). El cifrado nos garantiza que nadie podrá acceder a los datos si el HDD se extravía o es robado. Cada HDD puede almacenar al menos una copia de seguridad, pero si disponen de espacio suficiente, contendrán dos o más. El administrador irá borrando la más antigua si resulta necesario para la realización del nuevo backup.

4. Cada dos semanas, a las 23:00, el NAS realiza una copia de seguridad incremental en Amazon S3, eliminando automáticamente las anteriores a 60 días, que garantiza la disponibilidad de los datos ante catástrofes mayores como un terremoto.

2. Política de contraseñas

2.6 Política de copias de seguridad

2.6.5. Caso práctico: ejemplo de política de copia de seguridad en una pyme

5. Tanto el administrador del sistema como una o más personas de la dirección conocen las claves de cifrado (en los discos externos HDD eSATA) y de acceso al cloud Amazon S3.

De todos los trabajos de copia de seguridad aquí citados, solo el tercero (las copias externas) requiere de la intervención del administrador del sistema. El resto se realizan de forma automatizada y el administrador solamente tiene que revisar, de vez en cuando, que todo va bien (para lo cual, además, tanto Proxmox como el Synology le envían automáticamente informes por email).

Este ejemplo está basado en un "nivel de pánico" bastante elevado pues, como se puede comprobar, hay copias de seguridad redundantes y que podrían evitarse (¿cuáles?, ¿con cuál te quedarías tú y por qué?).

2. Política de contraseñas

Resumen

Las fases de un ataque a un sistema informático aprovechando vulnerabilidades o servicios mal configurados son: reconocimiento, escaneo, obtención de acceso, mantenimiento del acceso y borrado de huellas.
La mayoría de las medidas de seguridad lógica son tratadas a lo largo del libro, no solo en este capítulo.
La autenticación es el proceso por el cual un sistema informático confirma que alguien o algo es quien dice ser, e implica el uso de credenciales, habitualmente un nombre de usuario y una contraseña.
Es importante definir una política de contraseñas que defina, entre otras cosas, la complejidad mínima de las mismas y el período de vigencia de estas.
Se están imponiendo sistemas de autenticación en dos pasos o de doble factor (2FA).
Una vez un usuario ha sido autenticado, el sistema debe autorizar tu acceso a los recursos, lo cual se consigue asignando permisos y definiendo listas de control de acceso (ACL).
En redes empresariales es necesaria la utilización de un sistema de autenticación centralizado que facilite la administración de usuarios y permisos.
El sistema de inicio de sesión único o single sign-on (SSO) persigue la comodidad del usuario, que solo debe introducir sus credenciales una vez, pero puede acceder a varios servicios que requieren inicio de sesión.
Existen protocolos que aunan las funciones de autenticación, autorización y contabilidad, denominados AAA, como es el caso de RADIUS.

2. Política de contraseñas

Resumen

Una política de almacenamiento debe definir la ubicación, tipo, redundancia y alta disponibilidad de los sistemas de almacenamiento de datos empleados.

Las copias de seguridad son necesarias para recuperar datos borrados o corrompidos, pudiendo ser de tres tipos: completa, diferencial e incremental.

Una instantánea o snapshot no es un tipo especial de copia de seguridad, sino una característica de ciertos sistemas de ficheros que puede emplearse para realizar copias de seguridad consistentes y en caliente.

Las herramientas de copia de seguridad para servidores empresariales, entre las que se encuentran los respaldos en la nube, son mucho más potentes, complejas y caras que las disponibles para equipos individuales.

2. Política de contraseñas

ACTIVIDADES PROPUESTAS

2.1

Domain Password Audit Tool (DPAT) es un script hecho en Python cuya finalidad es analizar la fortaleza de las contraseñas de un dominio Active Directory. Lo encontrarás en la dirección https://github.com/clr2of8/DPAT. Sigue las instrucciones de la citada web y utilízalo para analizar las contraseñas de un dominio de pruebas o real al que tengas acceso.

2.2

Google ofrece dos métodos para acceder a sus cuentas que mejoran la seguridad respecto a la simple introducción de una contraseña. La primera es el uso del teléfono móvil para iniciar sesión, y la otra la verificación en dos pasos. Ambas se encuentran en Cuenta > Seguridad > Iniciar sesión. Configura ambas opciones en tu cuenta Gmail (o créate una si no dispones de ella) y comprueba su funcionamiento.

¿Cuál de las dos te parece más segura?

¿Qué ventajas e inconvenientes le ves a cada una de ellas?.

2. Política de contraseñas

2.3
Podemos configurar cualquier equipo en un NAS gracias a sistemas operativos de código abierto como:

FreeNAS
OpenMediaVault
XigmaNAS

Haciendo uso de un equipo o máquina virtual con 3 discos duros y con uno de estos sistemas operativos instalado (o haciendo uso de un NAS real, si dispones de él), configúralo para utilizar dos de sus discos en RAID 1.

Por último, observa el comportamiento del sistema cuando extraes uno de los discos del RAID. Vuelve a introducir el disco y comprueba cómo se replica de nuevo la información.

2.4
Continuando con el ejercicio práctico 2.3, configura el tercer disco como hot spare. Una vez replicado el contenido, extrae uno de los discos del RAID y comprueba el comportamiento del sistema. (Ten presente si tu sistema permite o no la extracción en caliente de los discos; si no es el caso, deberás apagar el sistema antes de proceder a la extracción, y luego volverlo a encender).

2. Política de contraseñas

2.5
Haciendo uso nuevamente del servicio anterior, configura la parte del RAID como volumen iSCSI o LUN. Crea un iSCSI Target en el mismo NAS para acceder a dicho volumen, y haz lo mismo en algún equipo Windows de la red local. Comprueba que, desde el punto de vista de Windows, está trabajando con un disco local (tiene una letra de unidad asignada y todo), y que todo lo que escribes en dicho target en Windows lo ves en el target del NAS.

2.6
Descarga el software Cobian Backup y crea uno o más trabajos de copia de seguridad. ¿Permite este software la restauración de ficheros individuales? Haz pruebas de copias y restauraciones.

2. Política de contraseñas

Actividades de autoevaluación

1.Según la Certified Ethical Hacker, ¿cuántas fases tiene todo ataque a un sistema informático?

a) Cinco.
b) Cuatro.
c) Tres.

2.Una vez que un atacante ha accedido a un sistema, se asegura un método para entrar en el futuro, denominado:

a) Vulnerability scanner.
b) Backdoor.
c) Dumpster diving.

3.Al finalizar el proceso de autenticación nos encontraremos con que:

a) El usuario no es identificado como un usuario autorizado y no se le permite iniciar sesión.
b) El usuario es identificado como un usuario autorizado y se le permite iniciar sesión.
c) Cualquiera de las opciones anteriores es válida.

2. Política de contraseñas

Actividades de autoevaluación

4.En una ACL solo se le pueden asignar permisos a grupos de usuarios.

a) Verdadero.

b) Falso, solo a usuarios individuales.

c) Falso, a grupos y usuarios, pero se aconseja asignarlos solo a grupos de usuarios.

5.Para el funcionamiento de SSO es necesaria la intervención de un servidor central en el que todas las aplicaciones confían, denominado:

a) Token.

b) SSO Server.

c) Servidor de identidades.

6.¿Qué significa AAA cuando hablamos de protocolos de autenticación?

a) Authentication, Assimilation and Assembling.

b) Administration, Actualisation and Authorization.

c) Authentication, Authorization and Accounting.

2. Política de contraseñas

Actividades de autoevaluación

7.¿Cuántos discos se pueden averiar en un RAID 5 para que no se produzca pérdida de datos?
a) Solo uno.
b) Tantos como discos tenga el RAID menos 1.
c) Varios, mientras no sea el disco que contiene los códigos de paridad.

8.¿Qué nombre recibe la unidad que un servidor iSCSI pone a disposición de los sistemas cliente?
a) iSCSI LUN.
b) iSCSI Target.
c) iSCSI Initiator.

9.Según la LOPD, los servidores que almacenan datos personales no pueden estar ubicados:
a) Fuera de España.
b) Fuera de la UE.
c) Pueden estar ubicados en cualquier parte del planeta, siempre que exista un contrato de confidencialidad

2. Política de contraseñas

Actividades de autoevaluación

10.¿Qué tipo de copia de seguridad permite file versioning?

a) Completa.
b) Diferencial.
c) Incremental.